

西安交通大学

课程实验报告

实验名称: WEB 安全实验

姓名: 林圣翔

学号: 2223312202

专业班级: 计试 2201

指导教师: 马小博教授

报告日期: 2025.12.21



一、实验目的

1. 搭建安全靶场，熟悉常见的 WEB 安全漏洞。
2. 了解并掌握相关工具寻找漏洞及注入点。
3. 掌握漏洞的保护方式。

二、实验平台

实验环境为在 VMWare 上安装的 Kali4 和 Ubuntu。

三、实验原理

1. 暴力破解登录(Brute Force)

暴力破解是一种基于穷举法的认证绕过攻击。攻击者假设目标系统认证机制（如登录接口）缺乏有效的账户锁定、验证码等防护措施，通过自动化工具（如 **Burp Suite**）向目标系统持续、大量地提交可能的用户名与密码组合（通常来源于预先准备的“字典”），直至尝试出正确的凭证，从而非法获取系统访问权限。其实质是利用认证逻辑的缺陷，进行大规模的自动化猜解。

实验中主要使用 **Burp Suite** 这一集成化渗透测试平台。其 **Intruder** 模块可拦截 HTTP/S 登录请求，并对请求中的密码字段（或其他参数）进行标记，然后加载密码字典，自动化地重放携带不同密码的请求，通过分析服务器返回的响应（如状态码、长度、内容差异）来识别成功的登录尝试。**Kali Linux** 系统已内置该工具。

在 DVWA 的“**Brute Force**”模块中，安全级别（**Low, Medium, High, Impossible**）的设置直接影响防护机制的强度（如是否对失败尝试进行限制、是否使用 **Token** 等）。通过对比不同级别下的攻击成功率与复杂度，可以直观理解防御措施的有效性。

2. SQL 注入 (SQL Injection)

SQL 注入是一种将恶意 SQL 代码插入或“注入”到 Web 应用输入参数（如表单字段、URL 查询字符串）中，并被后端数据库服务器误认为是合法 SQL 命令而执行的攻击。其根本原因在于应用程序未对用户输入进行充分的验证、过滤或转义，使得攻击者能够篡改原本预设的 SQL 查询结构。

攻击者通过精心构造的输入数据，例如在登录名的输入框中输入某些字符，意图闭合原查询语句的字符串，注释掉后续部分，或添加永真条件，从而绕过身份验证、窃取、篡改或删除数据库中的数据，甚至执行数据库管理命令。

DVWA 的“**SQL Injection**”模块模拟了存在注入漏洞的查询接口。通过在不同安全级别下进行测试，可以观察到防御措施的演进：从 **Low** 级别的无任何过滤，到 **Medium** 级别使用 `mysql_real_escape_string()` 进行部分转义，再到 **High** 级别使用预处理语句等更安全的方式，深刻理解代码层防护的重要性。

3. 中间人攻击 (Man-in-the-Middle, MITM)——基于 ARP 欺骗

在以太网局域网中，设备之间的通信最终依赖于物理地址（**MAC 地址**）。地址解析协

议（ARP）负责将目标设备的 IP 地址解析为对应的 MAC 地址。通信前，主机会先查询本地的 ARP 缓存表；若没有相应条目，则广播一个 ARP 请求，询问“IP 地址 X.X.X.X 对应的 MAC 地址是什么？”拥有该 IP 的设备会以单播方式回复自身的 MAC 地址，完成地址解析。

然而，ARP 协议在设计上存在安全缺陷：它是无状态的，并且缺乏身份认证机制。设备通常会无条件信任并更新其 ARP 缓存中接收到的任何 ARP 响应，无论该响应是否是对其主动请求的回复。这一信任机制成为 ARP 欺骗攻击能够实施的根本原因。

攻击者（例如主机 C）可以利用工具（如 Ettercap）持续向局域网广播伪造的 ARP 响应包，宣称：“网关的 IP 地址对应的是攻击者 C 的 MAC 地址”，同时声称：“目标主机 B 的 IP 地址对应的也是攻击者 C 的 MAC 地址”。这样，网关和主机 B 都会更新自身 ARP 缓存，误将攻击者 C 视为合法的通信对象。结果，所有原本直接在网关与主机 B 之间流通的网络流量，都会被重定向到攻击者 C 的主机，使其成功占据“中间人”位置。

一旦中间人攻击建立，攻击者可在不中断通信的情况下配置流量转发以维持隐蔽性，同时对流经的数据进行嗅探、篡改或重定向。例如，结合 driftnet 这类工具，攻击者能够实时截取并显示流经网络中的图片文件，直观展现中间人攻击如何窃取用户敏感信息（如浏览的图片）。

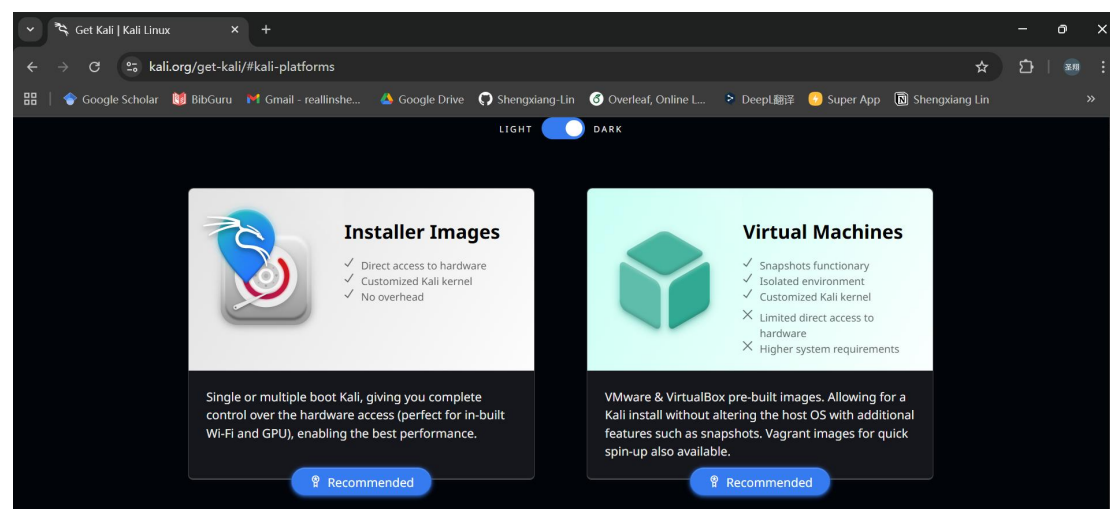
此攻击演示通常在实际局域网或虚拟网络环境中进行。虽然 DVWA 本身并未直接提供中间人攻击模块，但理解 ARP 欺骗的原理对于认识网络层安全、会话劫持以及 HTTPS 在防御数据窃听中的重要性至关重要。该实验是网络渗透测试中的重要环节，独立于 DVWA 进行，有助于深入理解网络协议的安全风险及防护必要性。

四、实验步骤

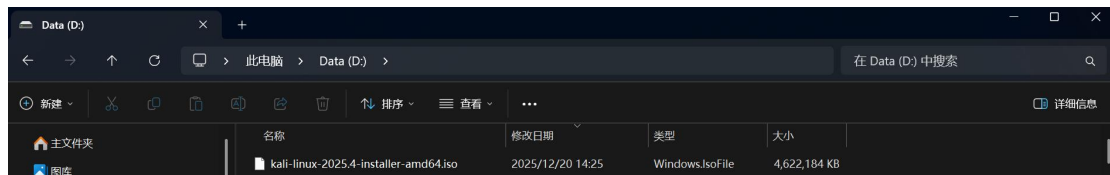
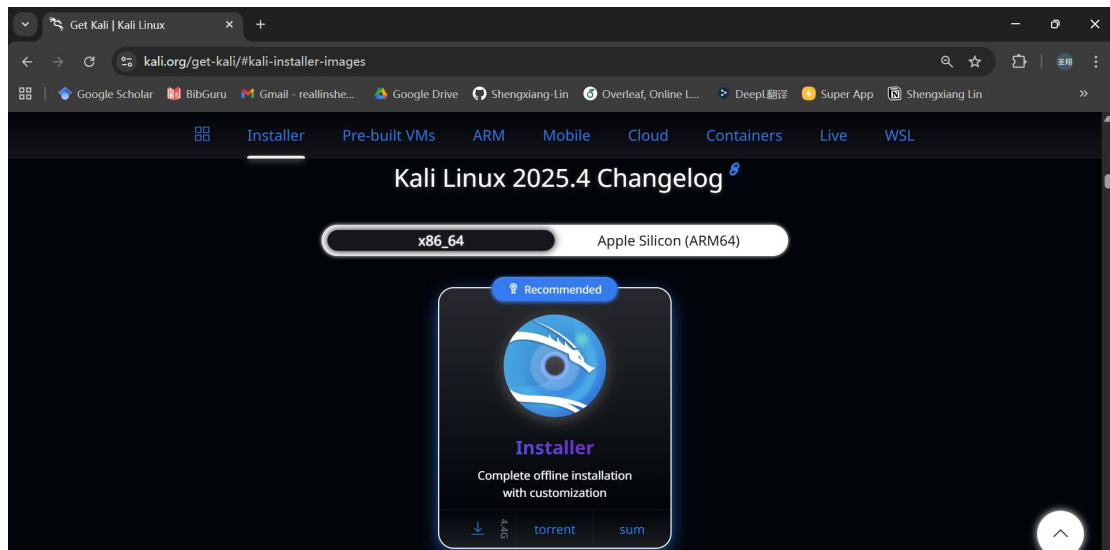
1.DVWA 靶场搭建

1.1.参考安装教程 https://blog.csdn.net/weixin_43676350/article/details/153460061，在虚拟机平台 VMWare 上安装 Kali 2025.4。

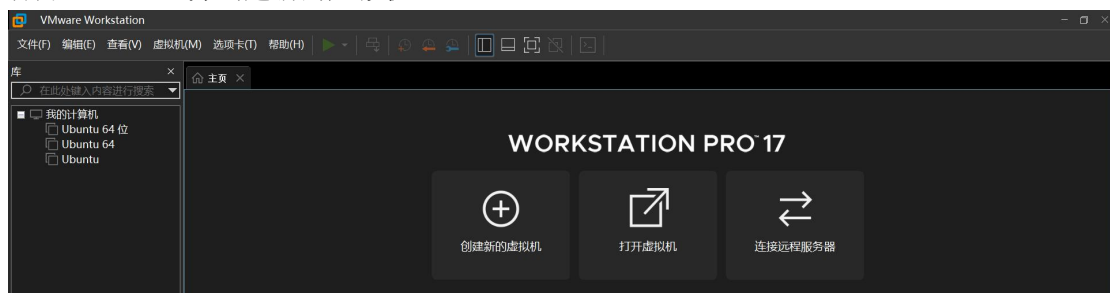
访问 Kali Linux 官方网站：<https://www.kali.org/get-kali/>。



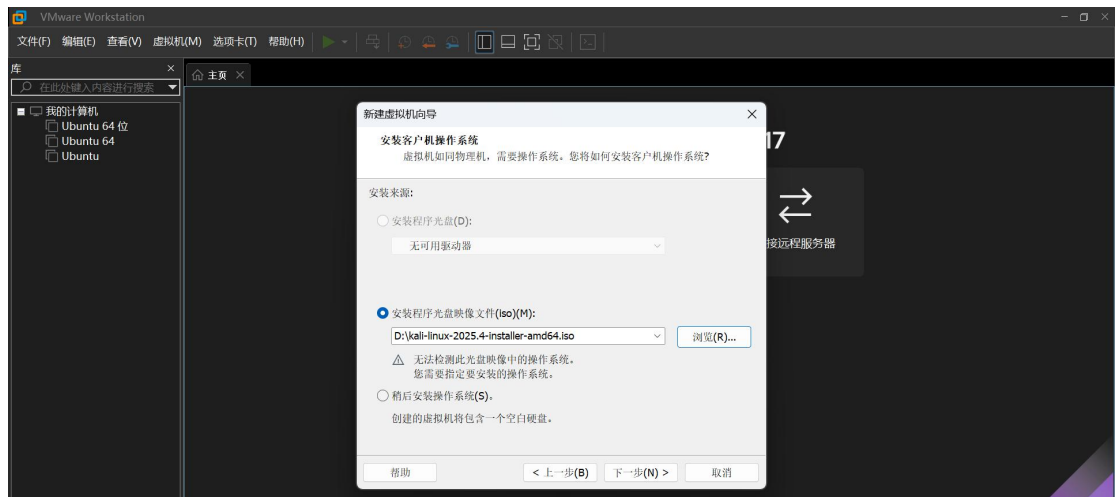
选择 Inataller Images，随后选择 x86_64 下载。



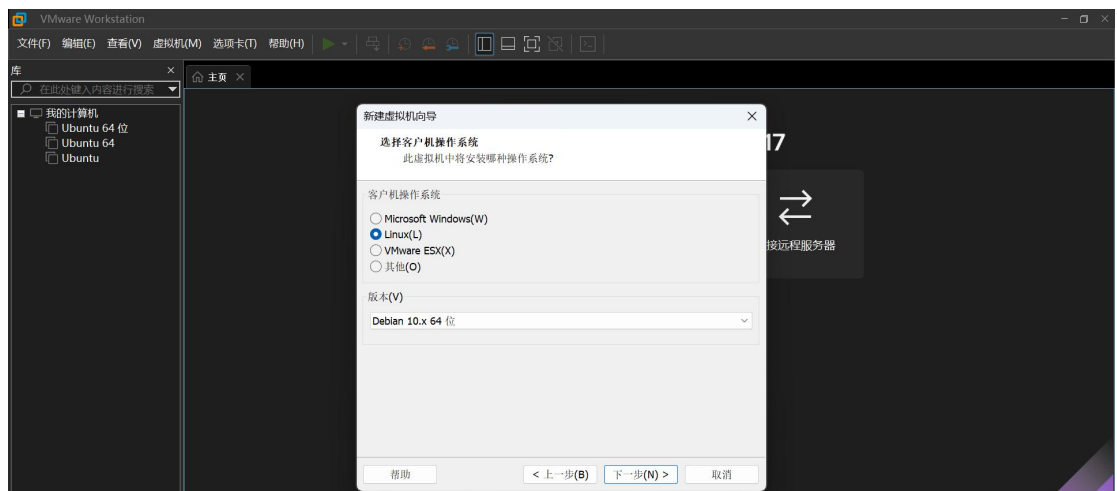
打开 VMware 并创建新的虚拟机。



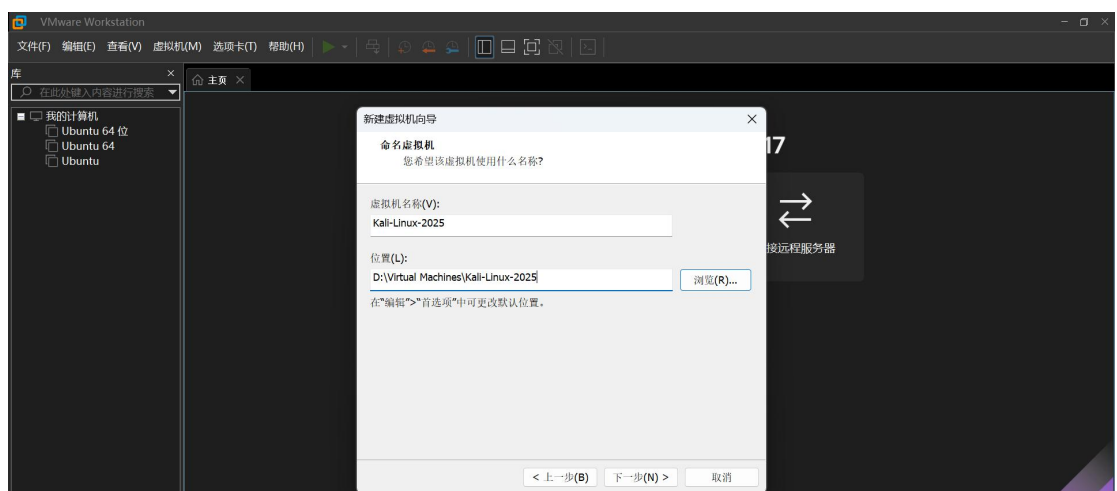
安装客户机操作系统。



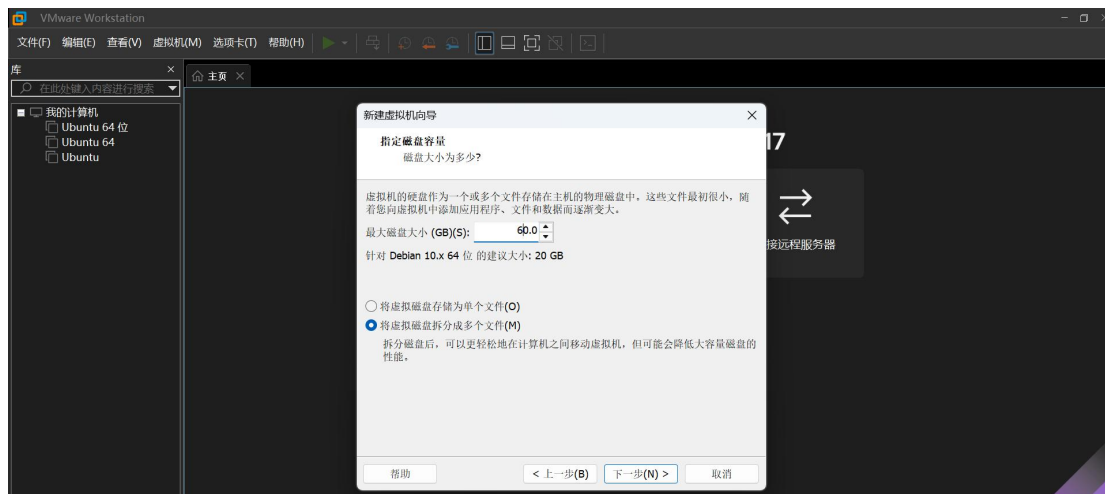
选择客户机操作系统。



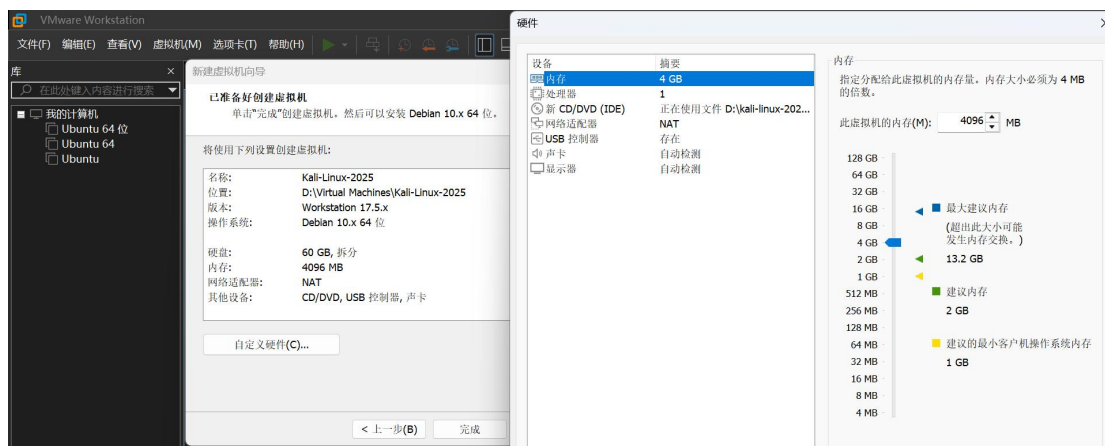
命名虚拟机。



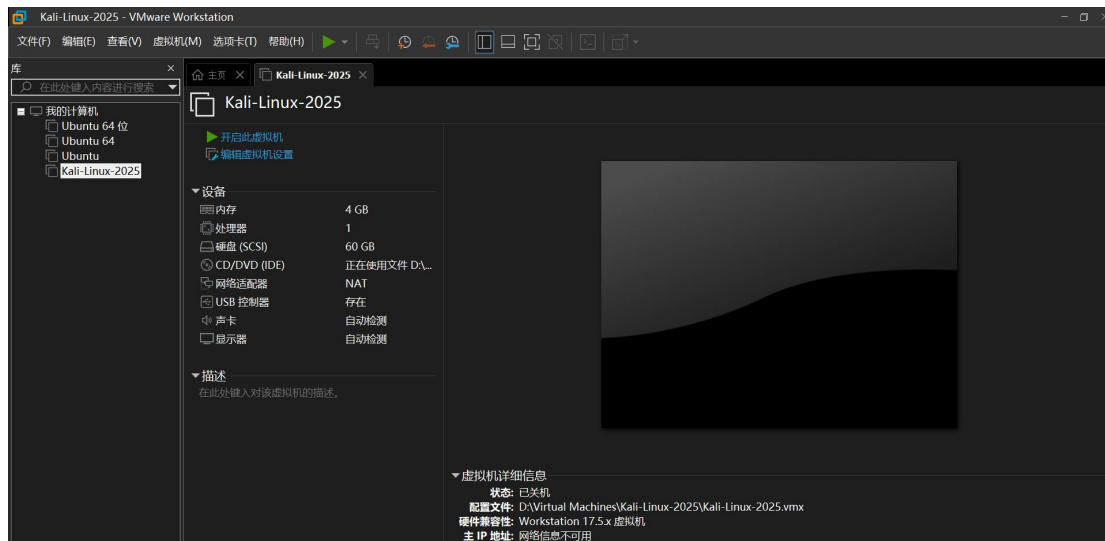
指定磁盘容量。



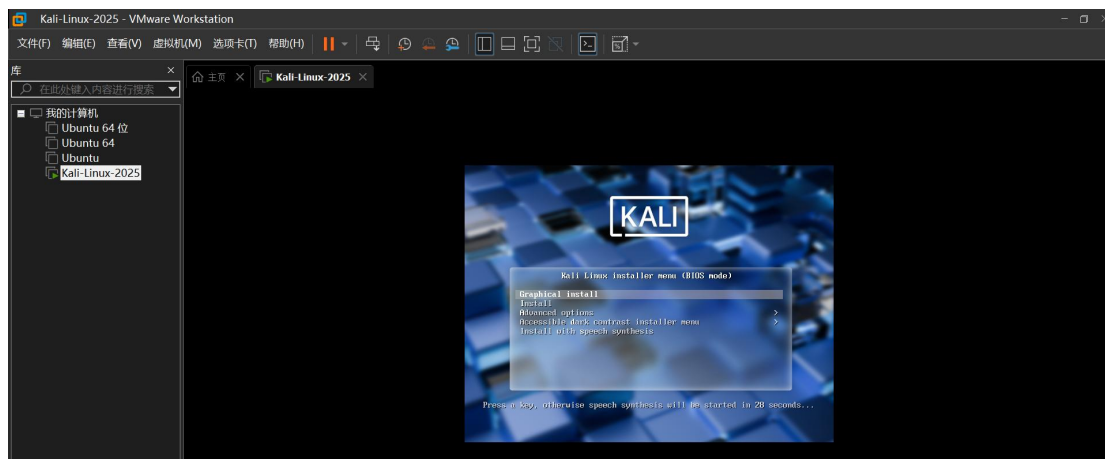
自定义硬件。



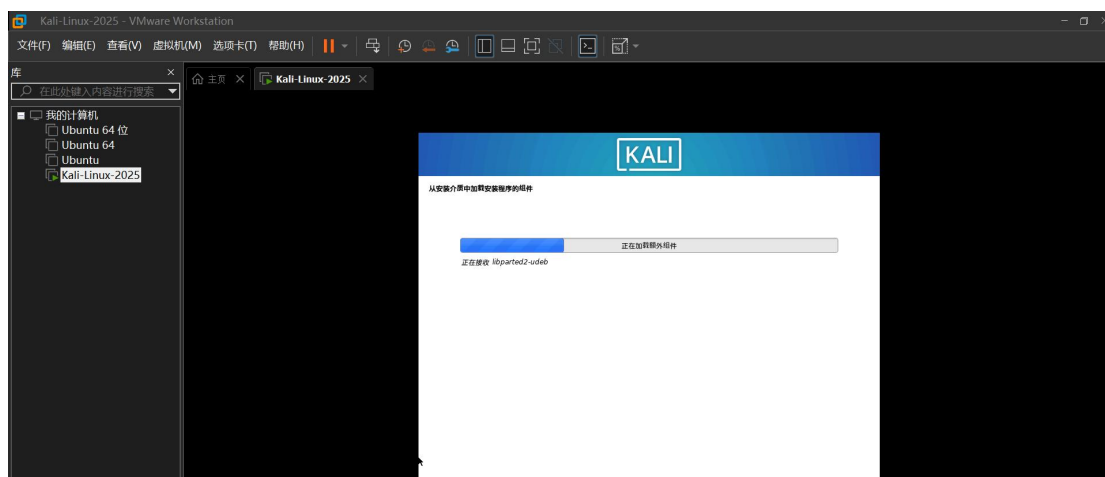
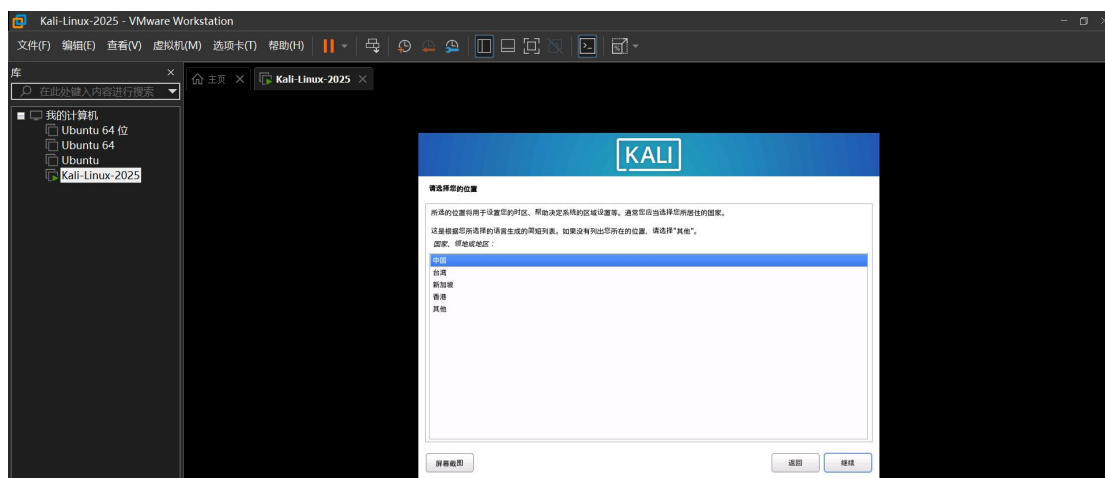
点击完成。



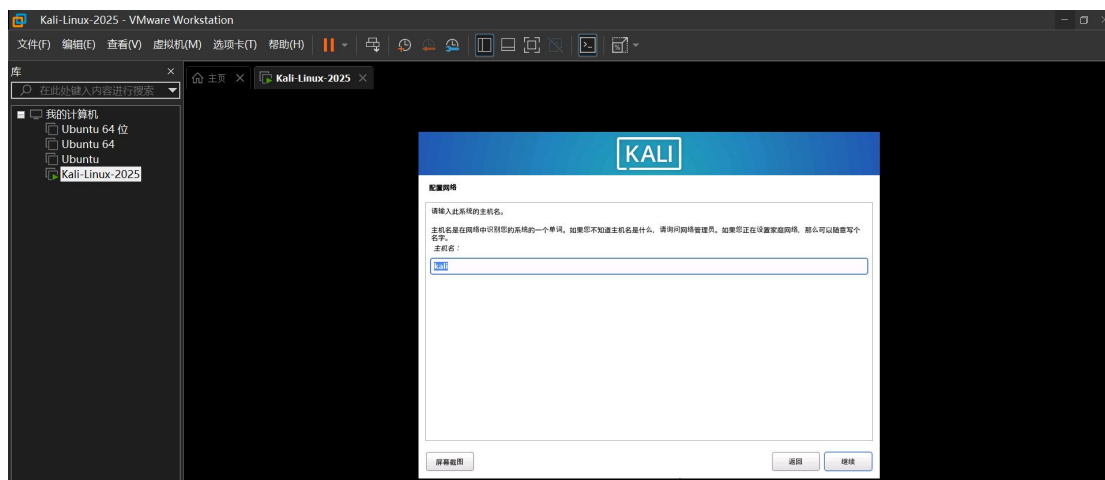
启动虚拟机，选择 “Graphical install”（图形化安装）。



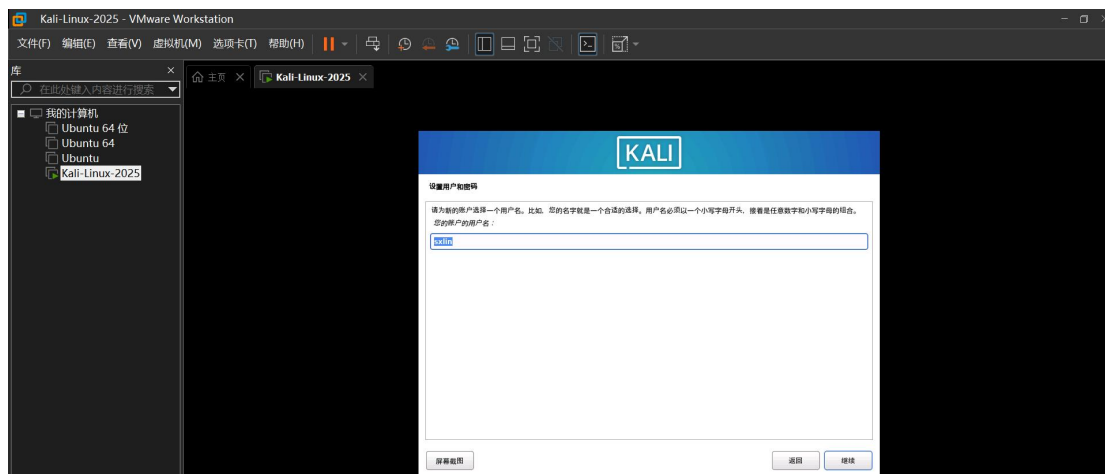
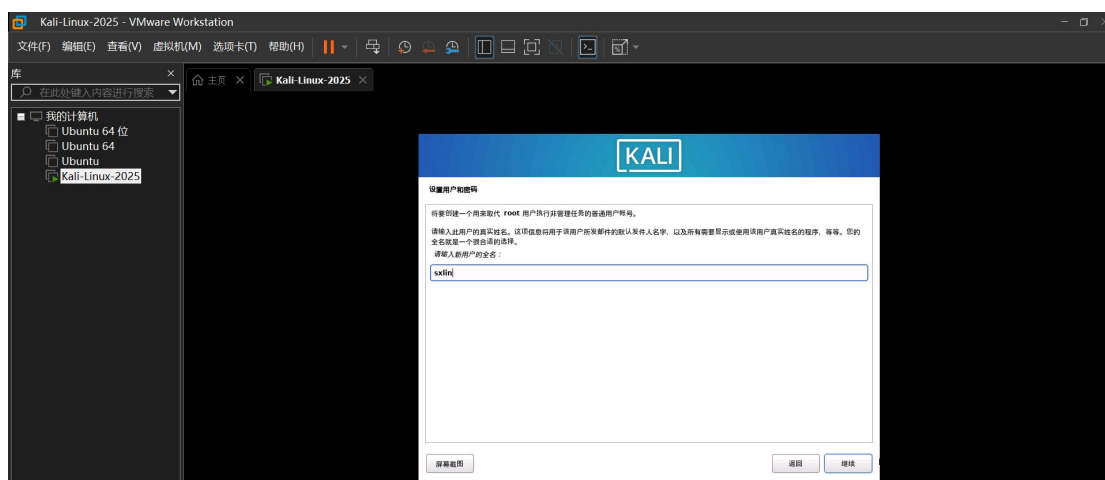
选择语言、地区等。



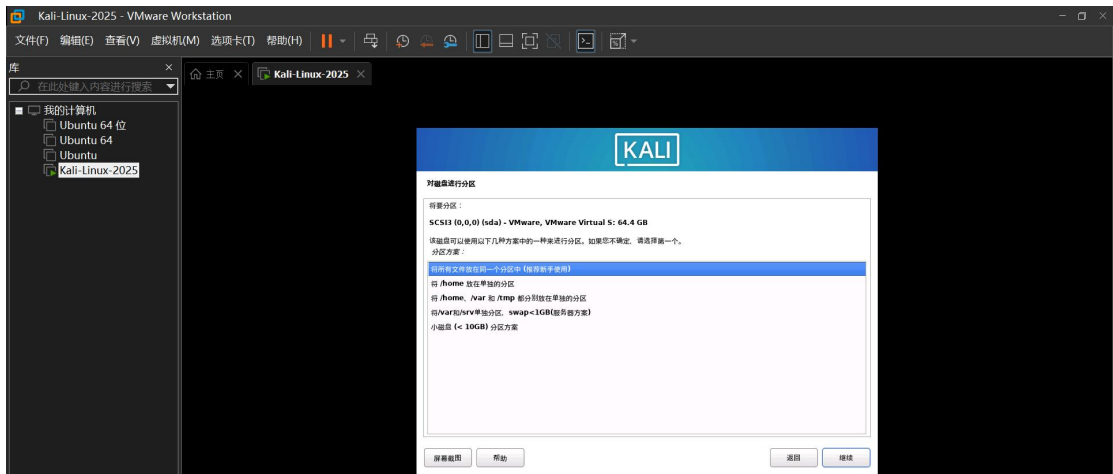
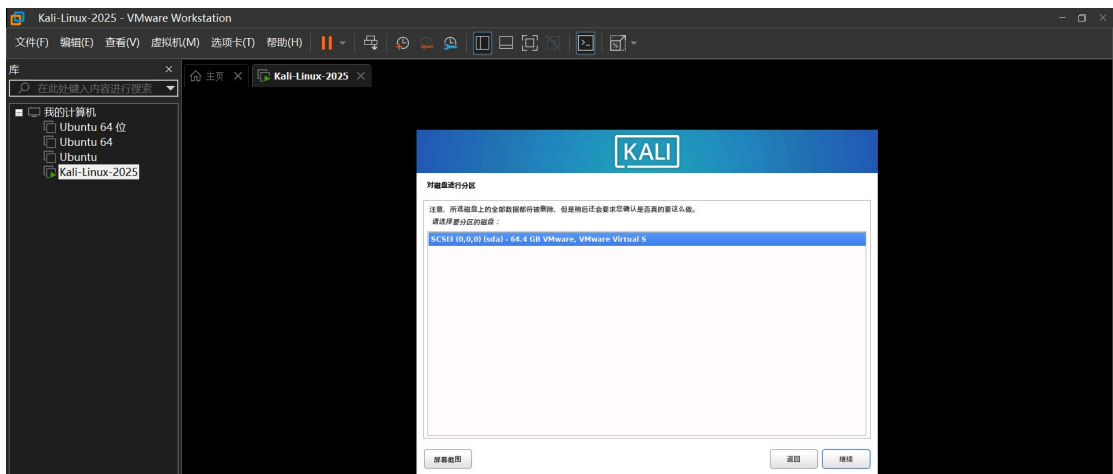
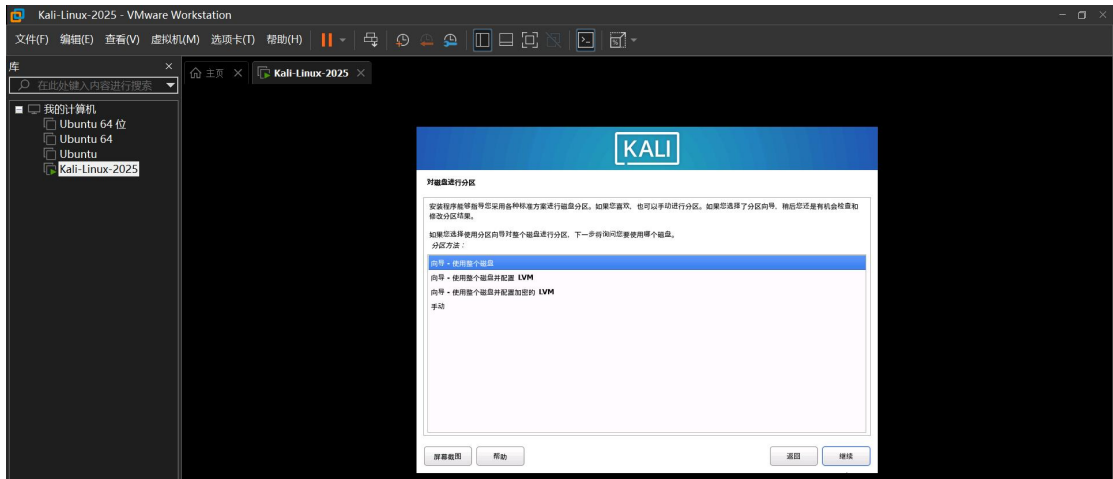
配置网络（默认选项）。

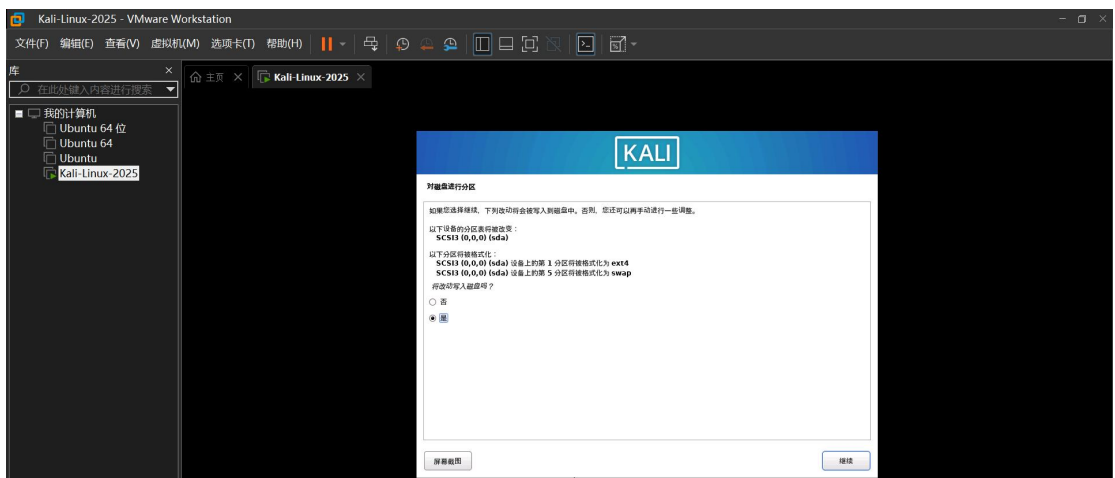
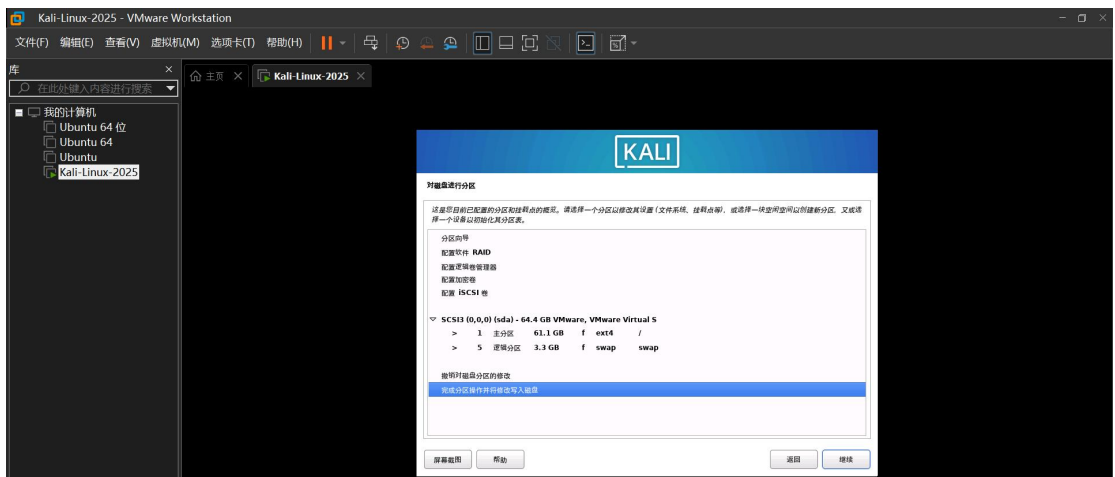


设置用户名、密码等。

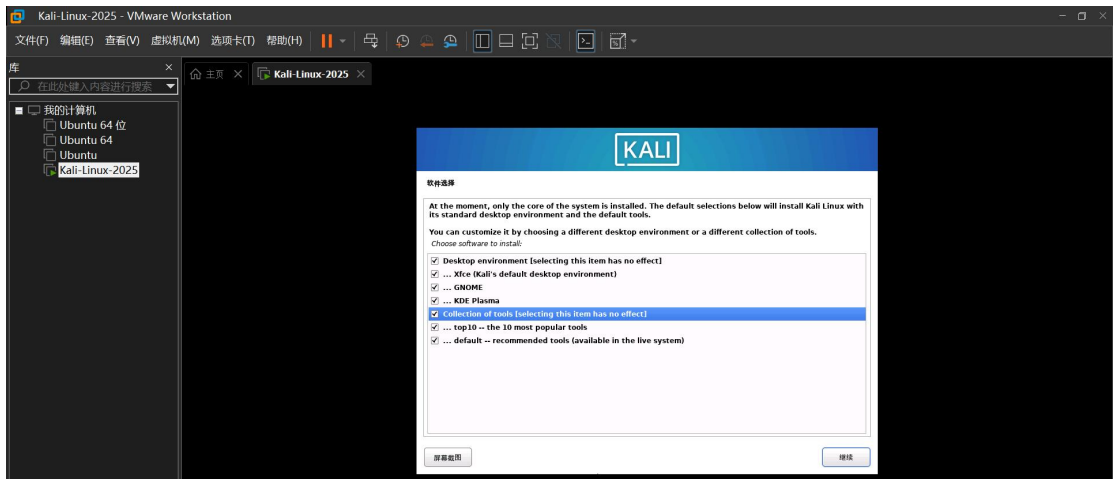


磁盘分区，使用整个磁盘。

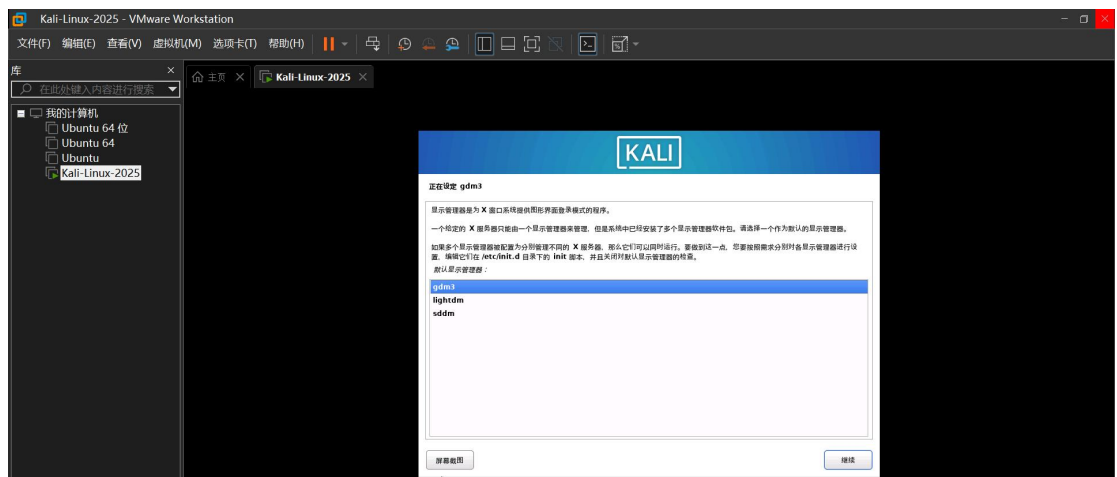




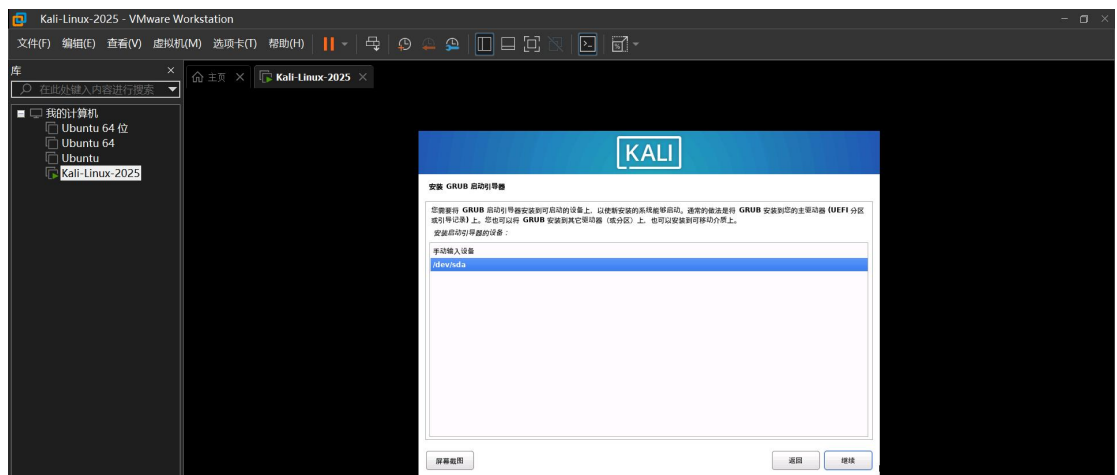
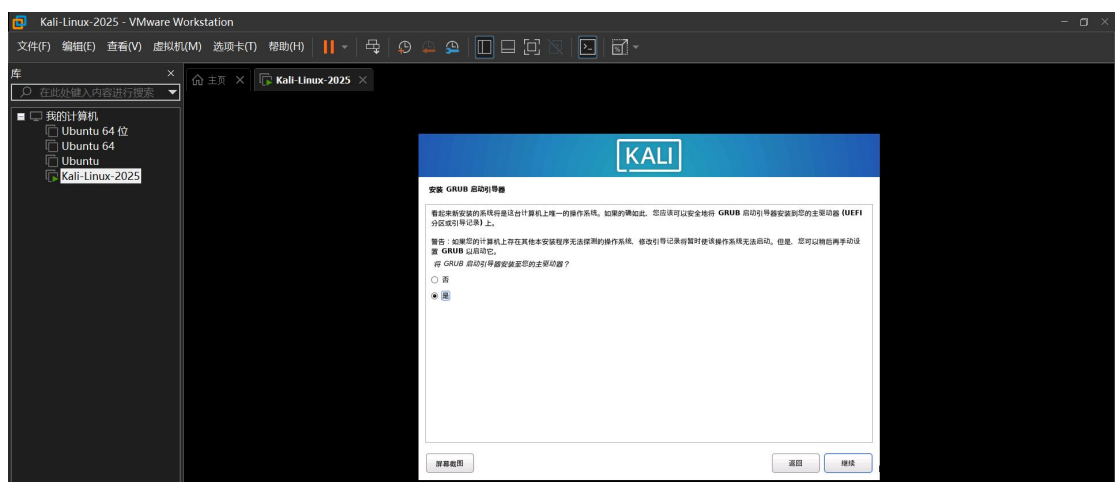
软件选择，全选。



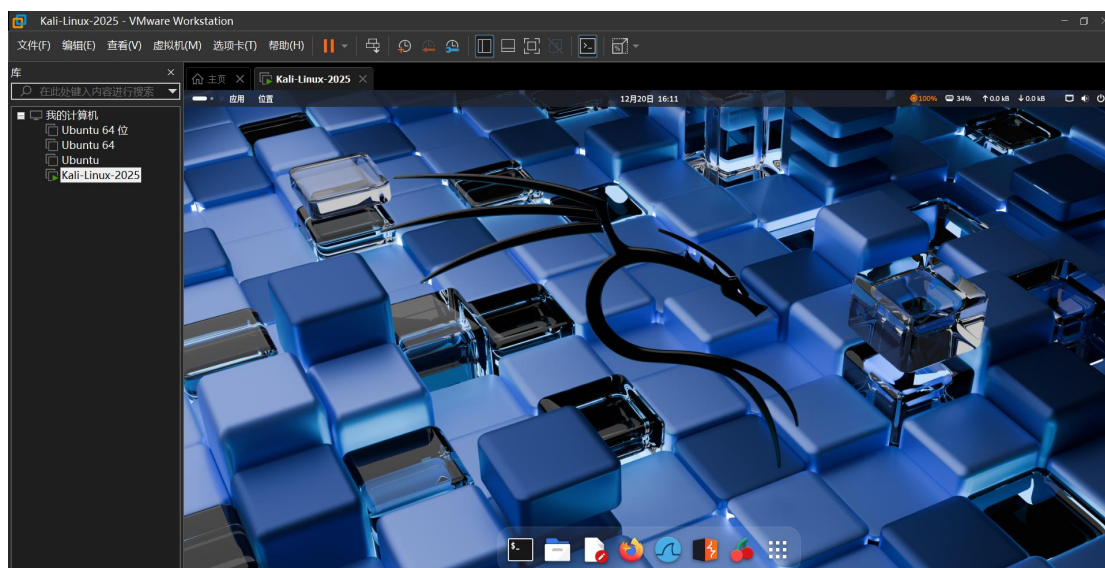
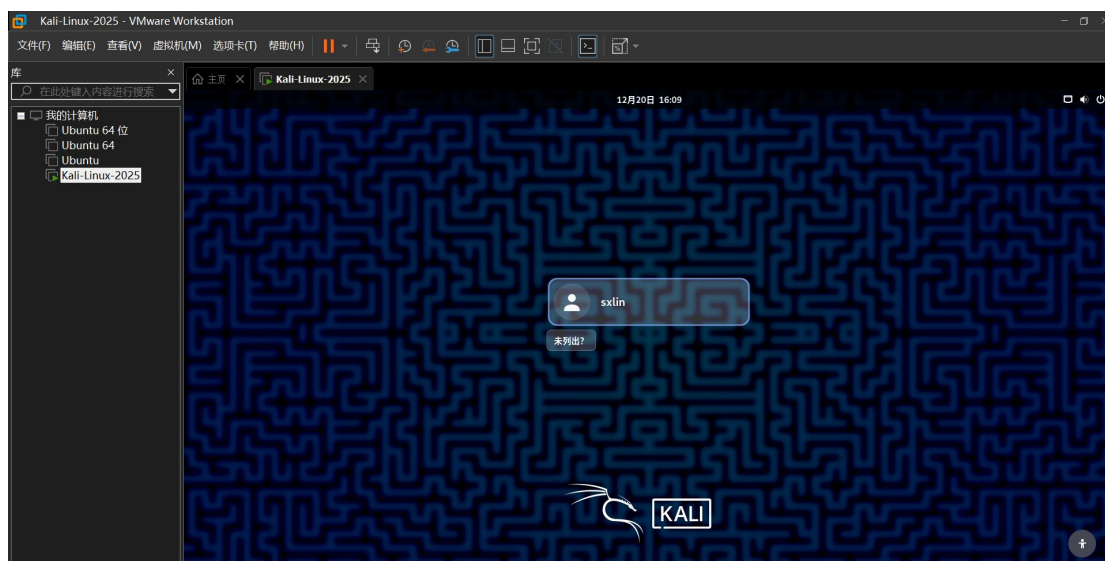
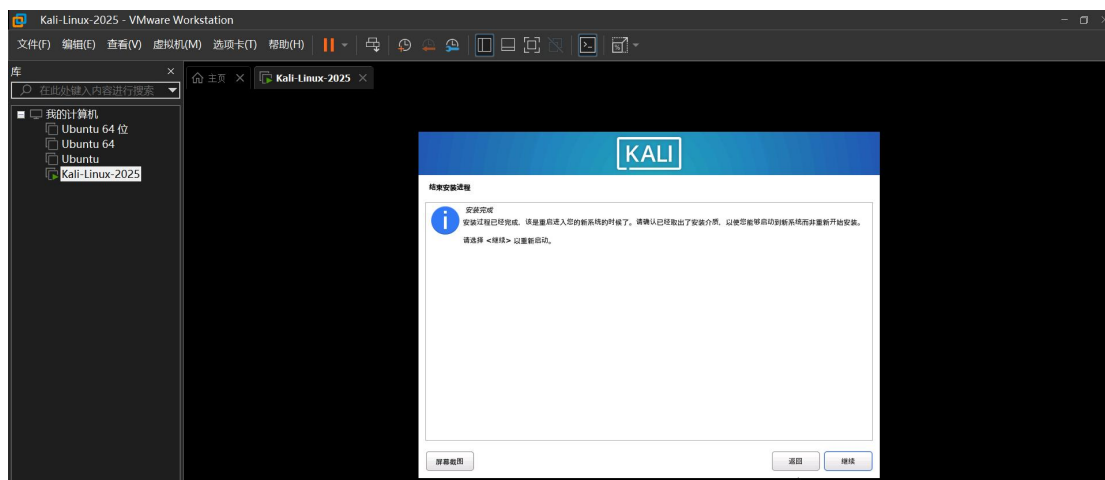
显示管理器选择保持默认。



安装 GRUB 引导程序。



完成安装。

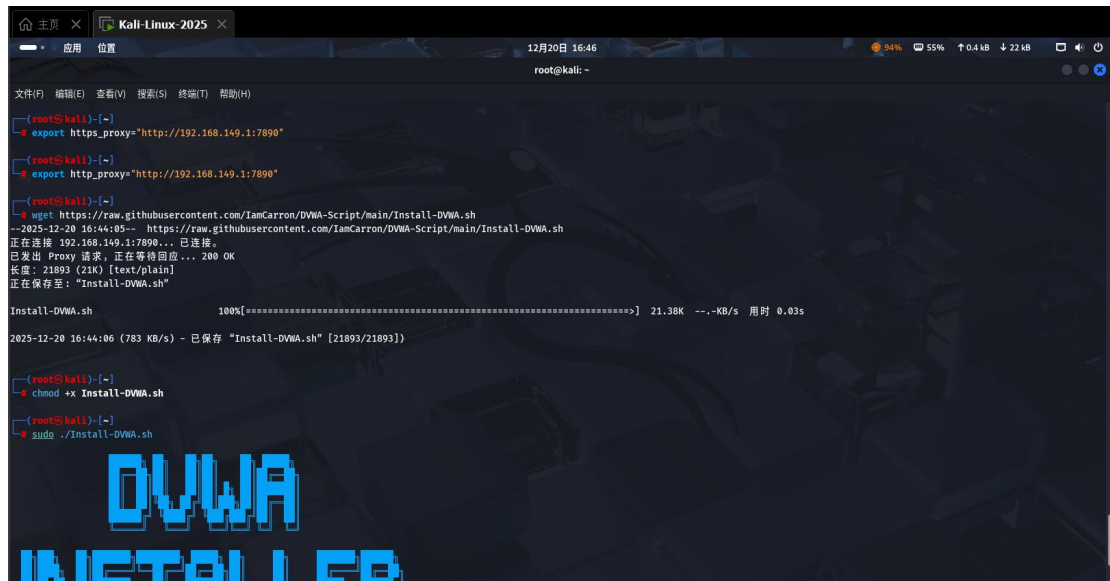


1.2 官方提供了安装脚本，先设置代理，随后使用如下命令安装 DVWA。

wget <https://raw.githubusercontent.com/IamCarron/DVWA-Script/main/Install-DVWA.sh>

chmod +x Install-DVWA.sh

sudo ./Install-DVWA.sh



```
(root@kali)~# export https_proxy="http://192.168.149.1:7890"
(root@kali)~# export http_proxy="http://192.168.149.1:7890"
(root@kali)~# wget https://raw.githubusercontent.com/IamCarron/DVWA-Script/main/Install-DVWA.sh
--2025-12-20 16:44:05-- https://raw.githubusercontent.com/IamCarron/DVWA-Script/main/Install-DVWA.sh
正在连接 192.168.149.1:7890... 已连接。
已发出 Proxy 请求，正在等待回应... 200 OK
长度：21893 (21K) [text/plain]
正在保存至: "Install-DVWA.sh"

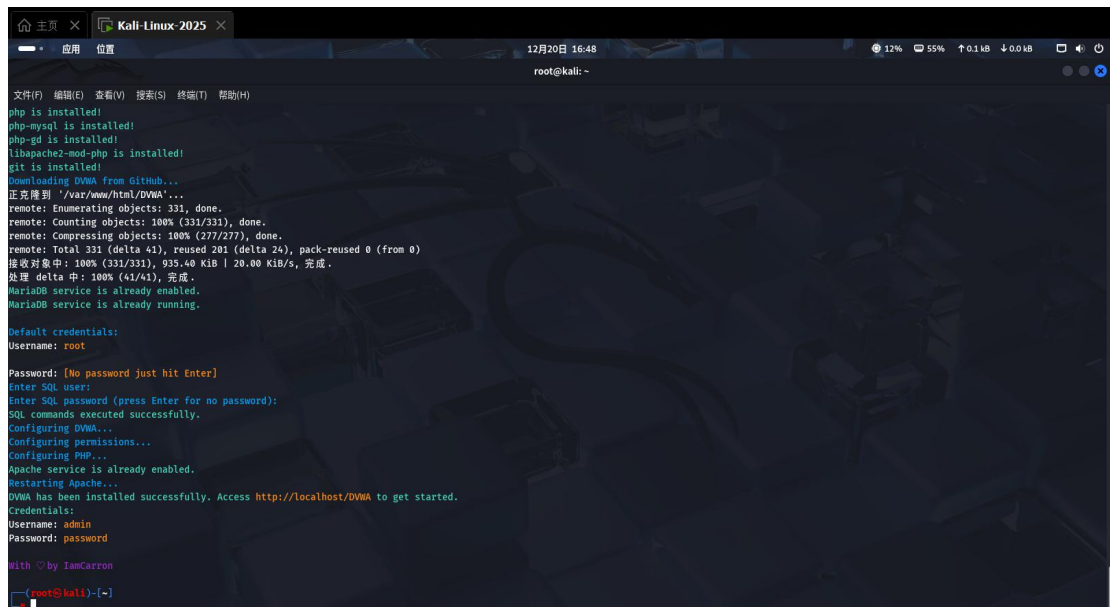
Install-DVWA.sh          100%[=====] 21.38K  --.-KB/s  用时 0.03s

2025-12-20 16:44:06 (783 KB/s) - 已保存 "Install-DVWA.sh" [21893/21893]

(root@kali)~# chmod +x Install-DVWA.sh
(root@kali)~# sudo ./Install-DVWA.sh

DVWA
INSTALLED
```

1.3.安装完成后会给出访问的网址 <http://localhost/DVWA> 和登录 DVWA 时使用的用户名和密码 admin/password。



```
php is installed!
php-mysql is installed!
php-gd is installed!
libapache2-mod-php is installed!
git is installed!
Downloading DVWA from GitHub...
正克隆到 '/var/www/html/DVWA'...
remote: Enumerating objects: 331, done.
remote: Counting objects: 100% (331/331), done.
remote: Compressing objects: 100% (277/277), done.
remote: Total 331 (delta 41), reused 201 (delta 24), pack-reused 0 (from 0)
接收对象中: 100% (331/331), 935.40 KiB | 20.00 KiB/s, 完成。
处理 delta 中: 100% (41/41), 完成。
MariaDB service is already enabled.
MariaDB service is already running.

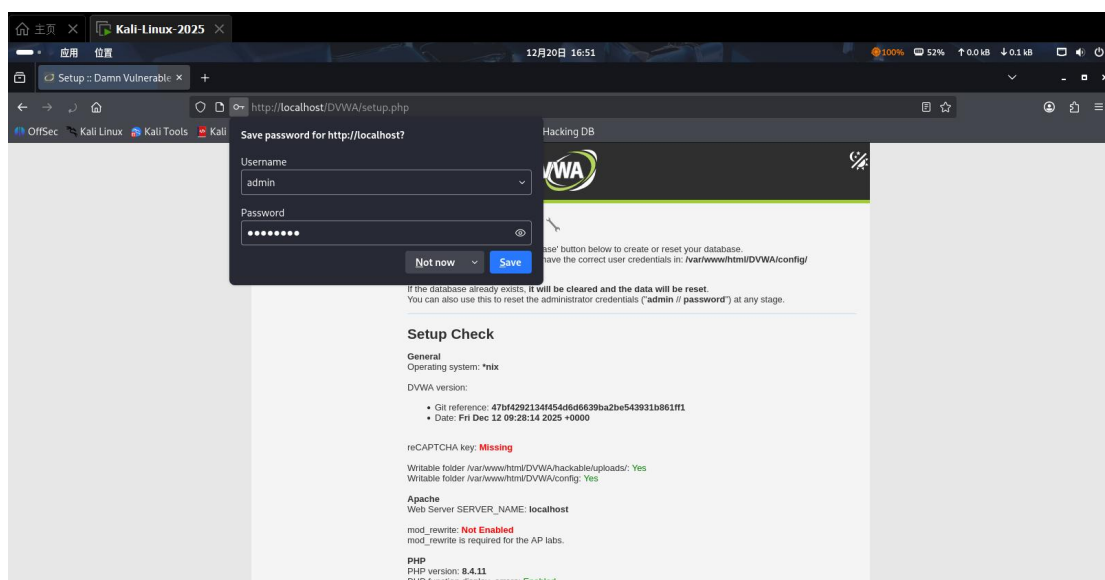
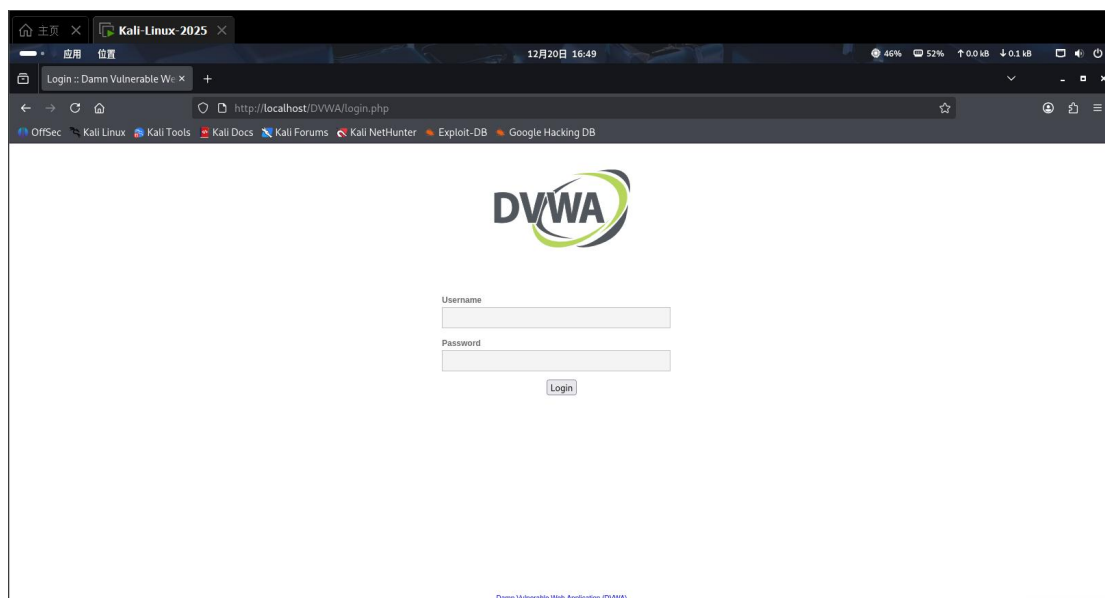
Default credentials:
Username: root

Password: [No password just hit Enter]
Enter SQL user:
Enter SQL password (press Enter for no password):
SQL commands executed successfully.
Configuring DVWA...
Configuring permissions...
Configuring PHP...
Apache service is already enabled.
Restarting Apache...
DVWA has been installed successfully. Access http://localhost/DVWA to get started.
Credentials:
Username: admin
Password: password

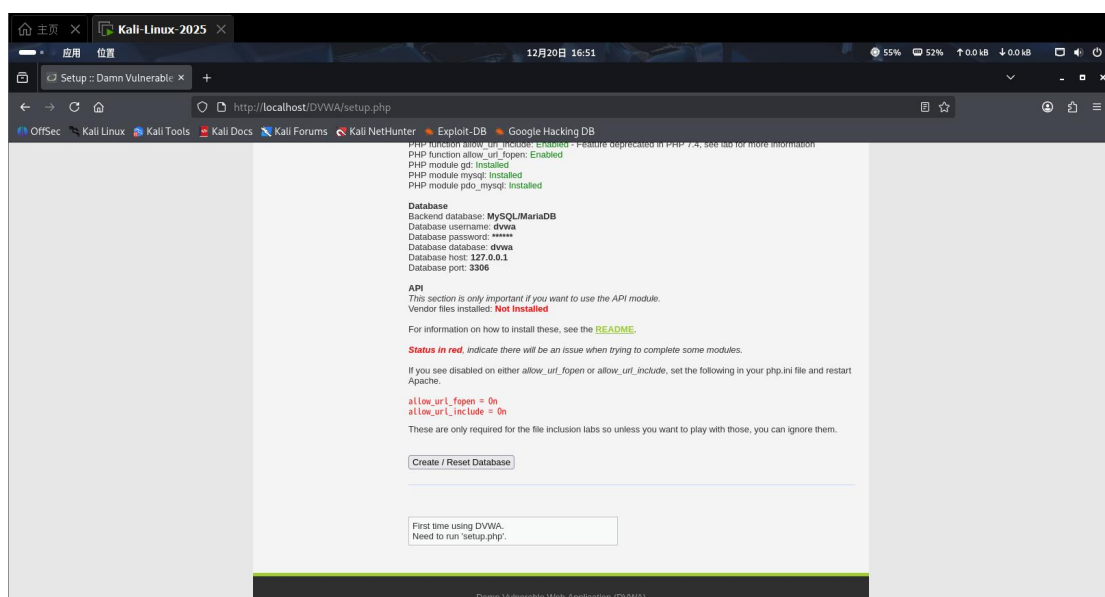
With ❤️ by IamCarron

(root@kali)~#
```

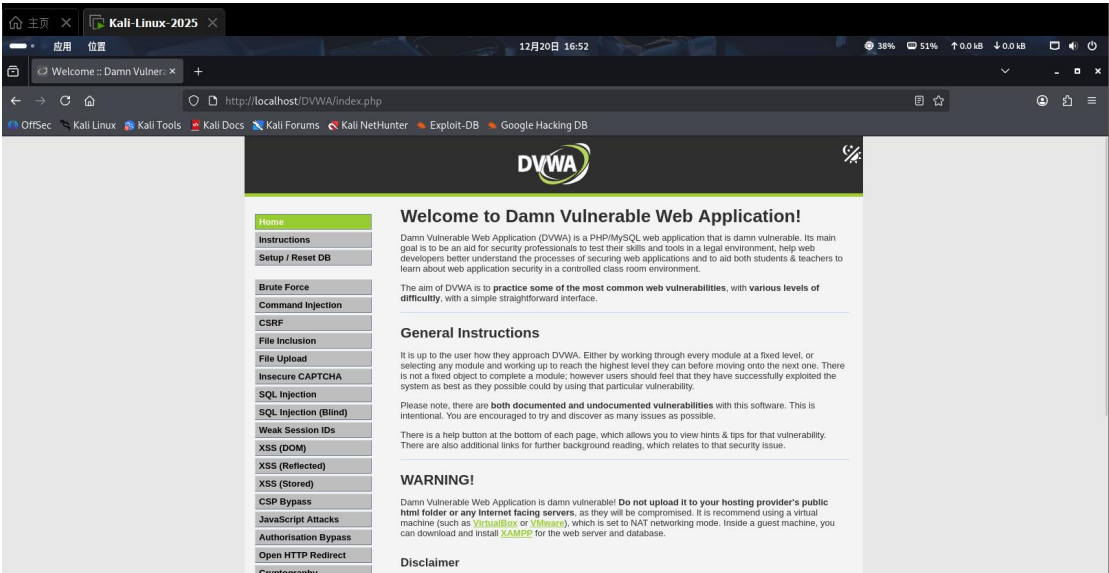
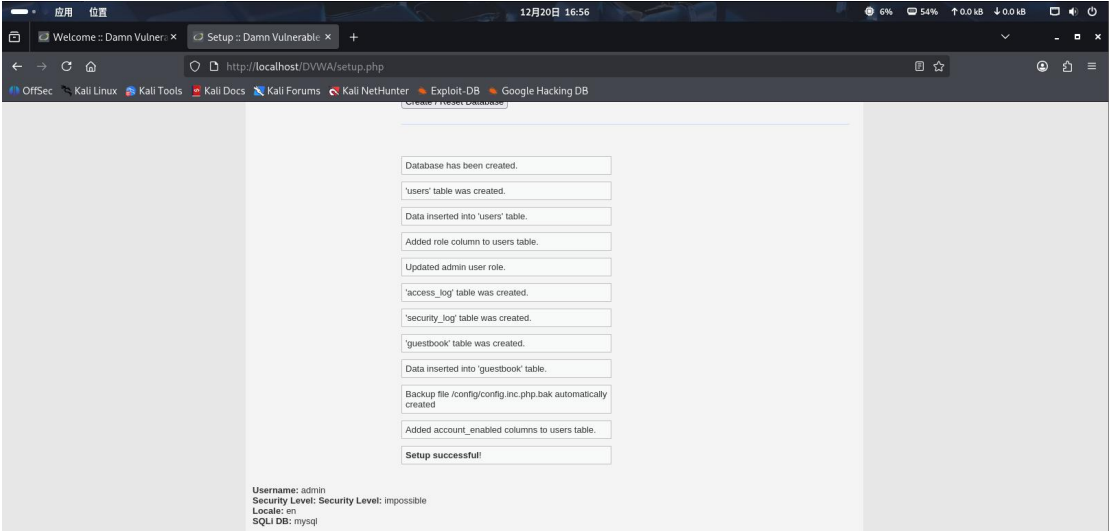
1.4.在浏览器中打开靶场，访问 <http://localhost/DVWA> ，使用上一步中得到的 admin/password 登录。



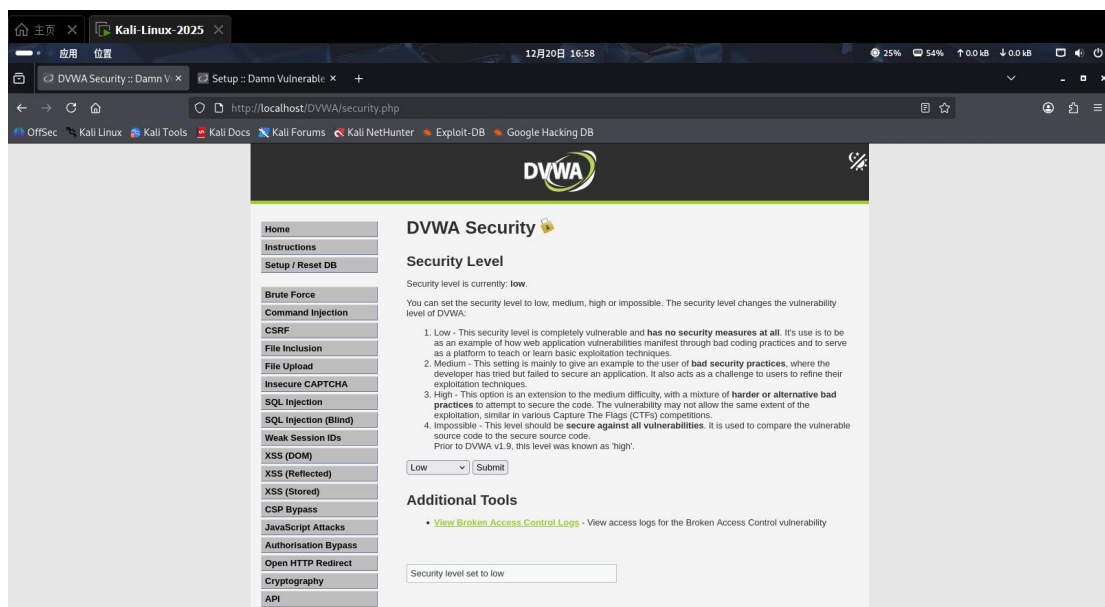
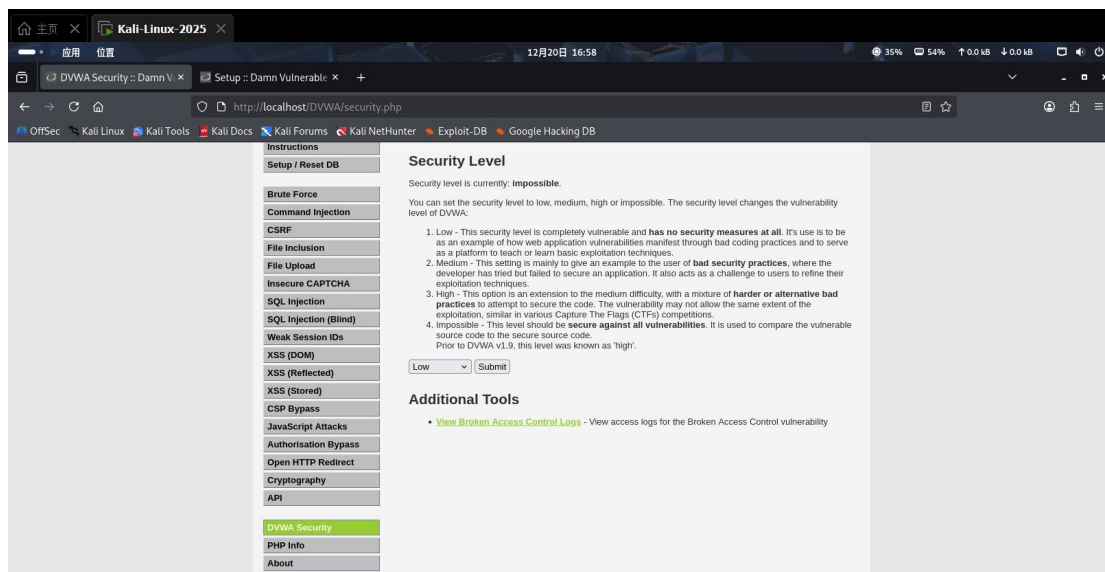
1.5.登陆成功后，拉到最下面点击创建数据库。



1.6.当看到如下提示时说明创建成功，系统会自动跳转到登录页面，重新登录，登陆后到如下页面说明登陆成功。

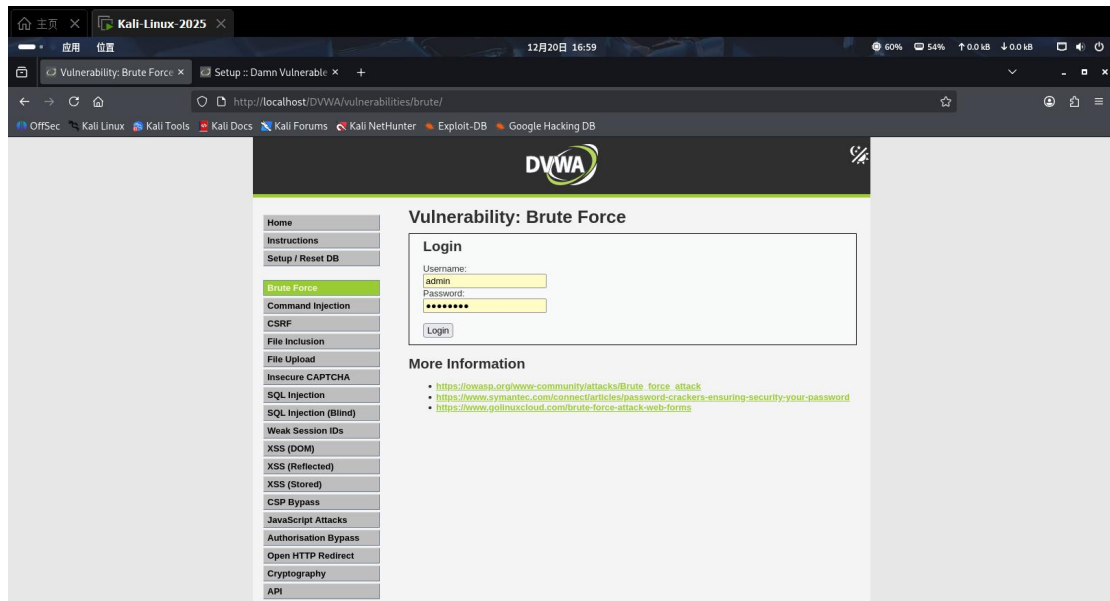


1.7.选择 DVWA Security 标签，将安全等级调整为 low，提交，提交完成后安全等级应该显示为 low。

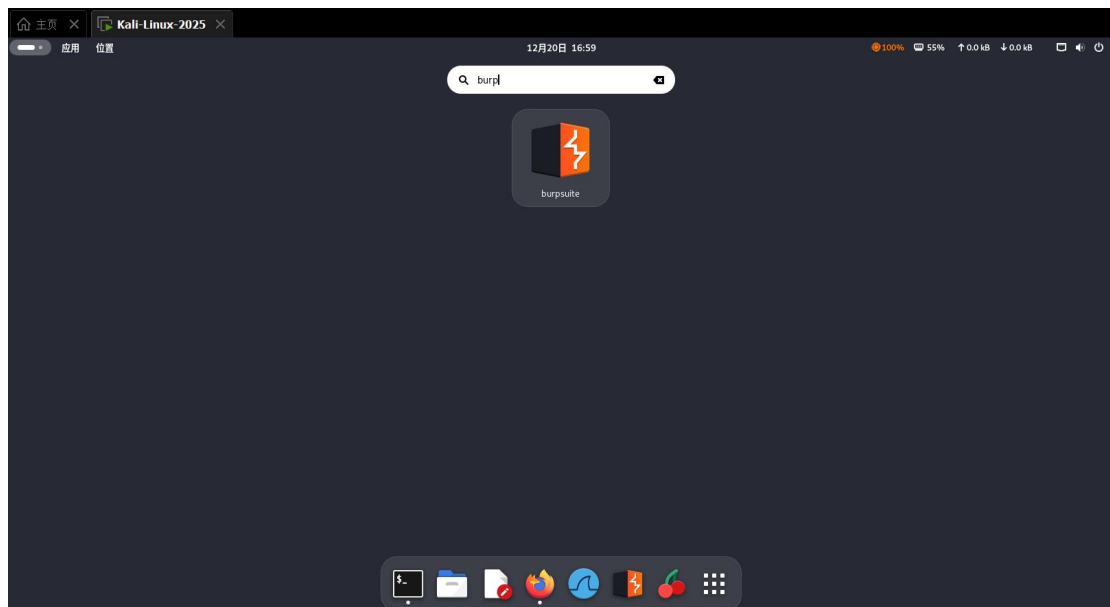


2.Brute Force 暴力破解

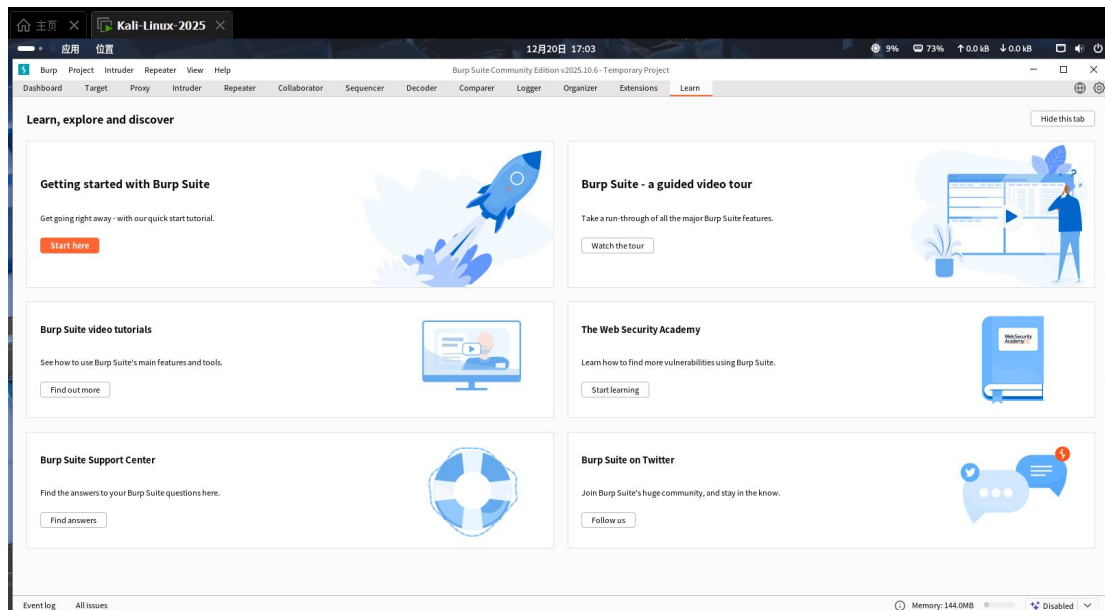
2.1.默认密码为 password。



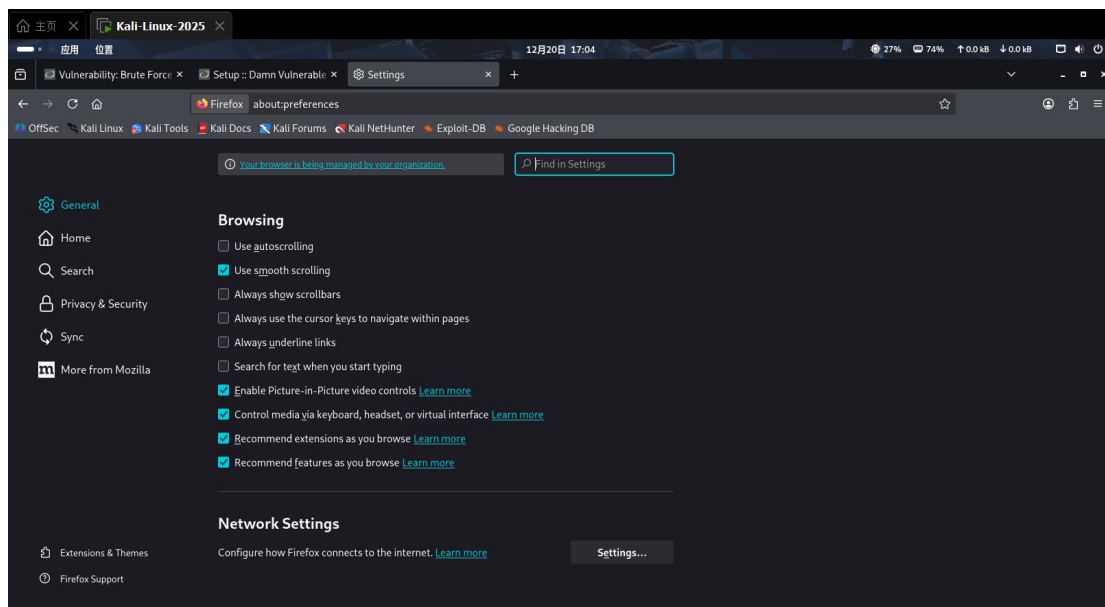
2.2.Kali 本身已经集成了 BurpSuite，直接打开即可。



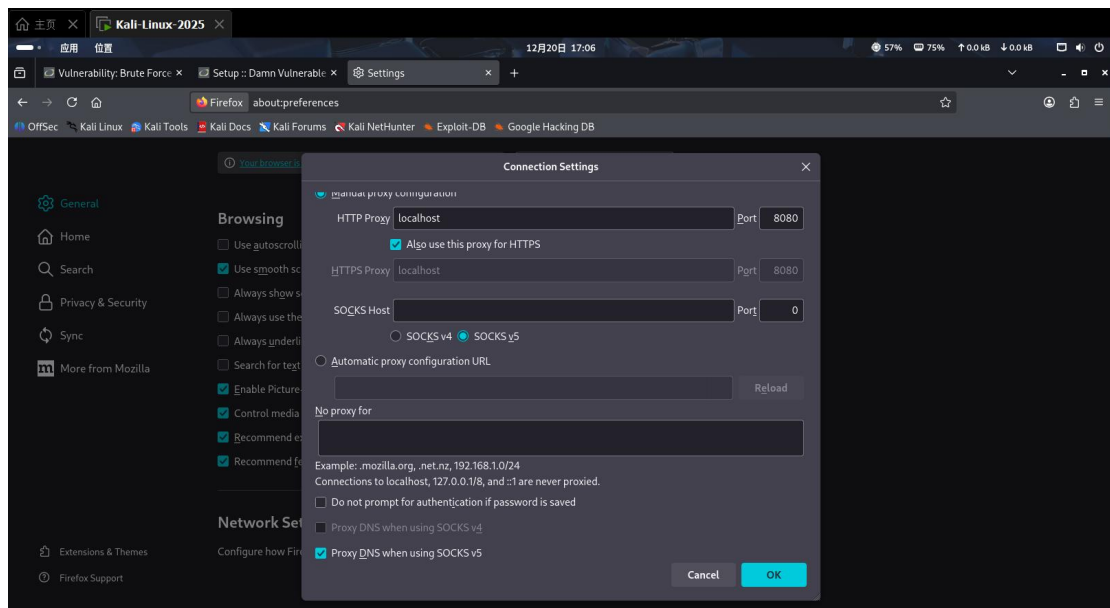
BurpSuite 界面。



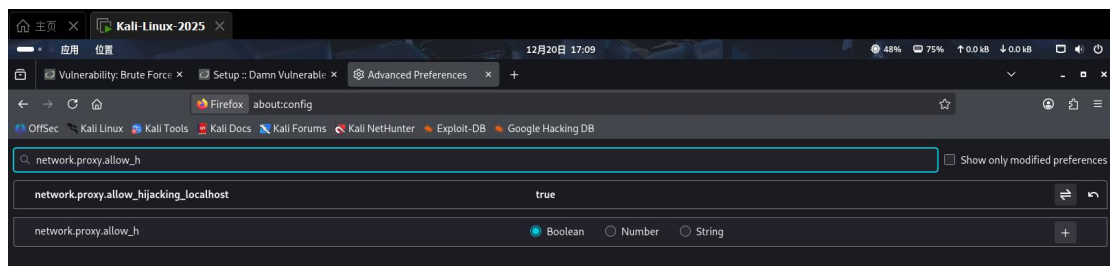
2.3. 首先设置浏览器的代理设置为 Burpsuite。



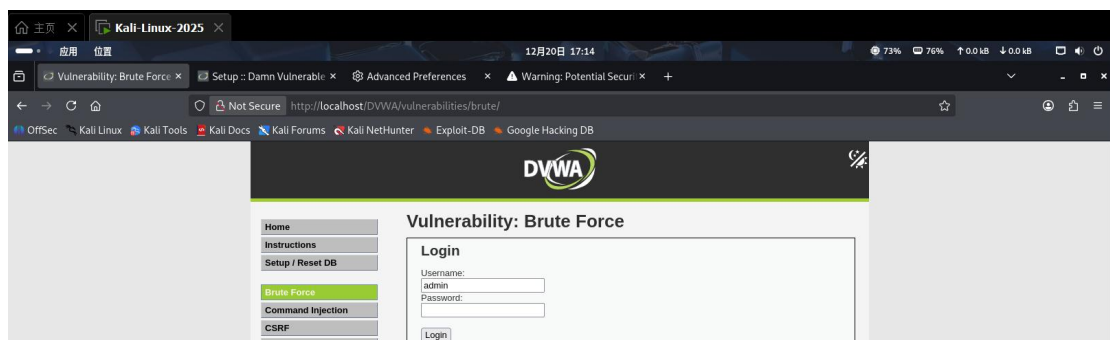
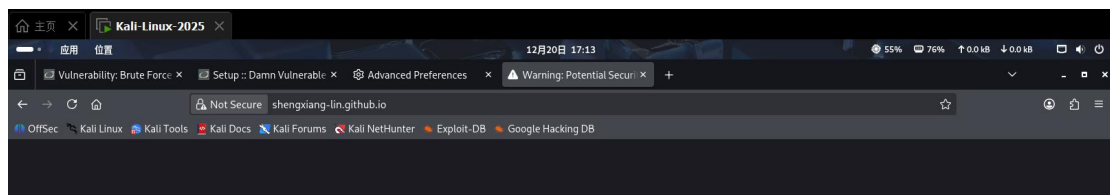
2.4. Burpsuite 提供的代理端口为 8080。设置代理为 localhost:8080。如果 No Proxy for 中有内容，需要删去。

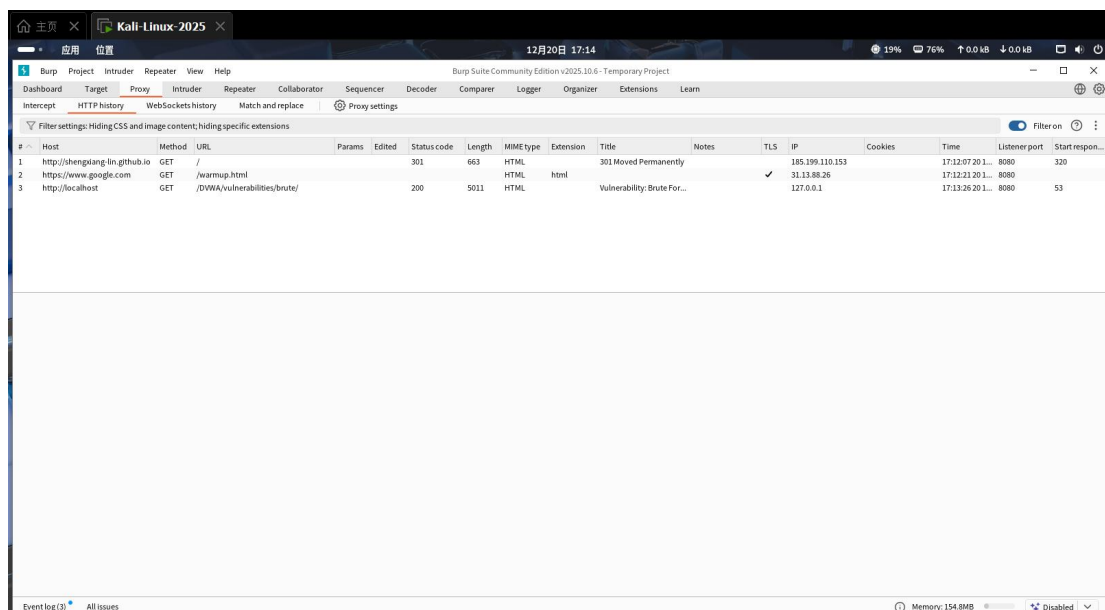


2.5.检查 firefox 本身是否允许抓取环回地址的数据包。在火狐浏览器的 url 栏输入 about:config, 在搜索栏输入 network.proxy.allow_hijacking_localhost, 如果其值为 false, 将值改成 true。

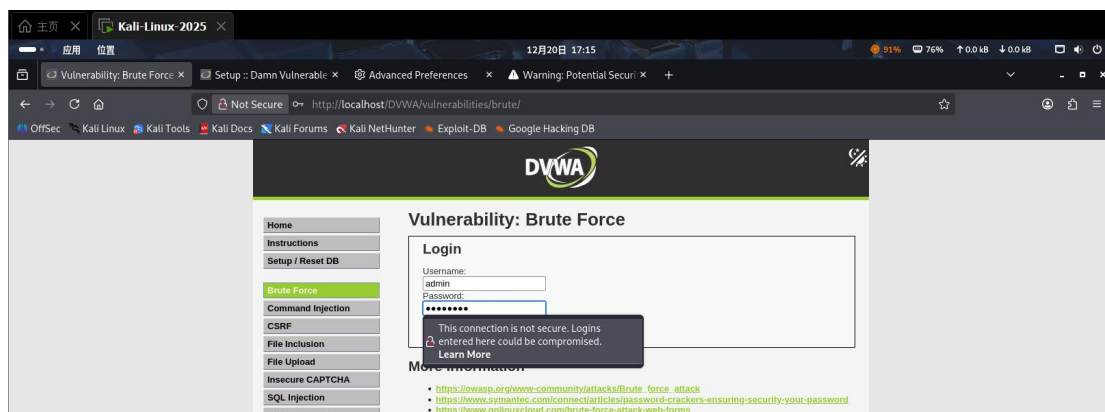


2.6.随便打开一个网页或者刷新已打开的页面, 可发现软件成功拦截到了包。

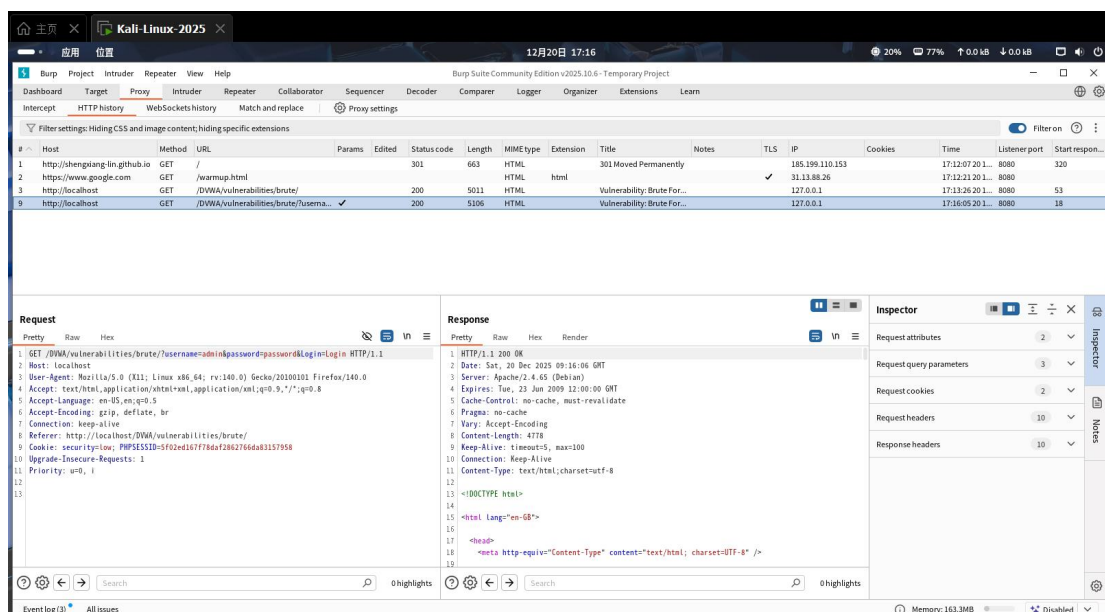




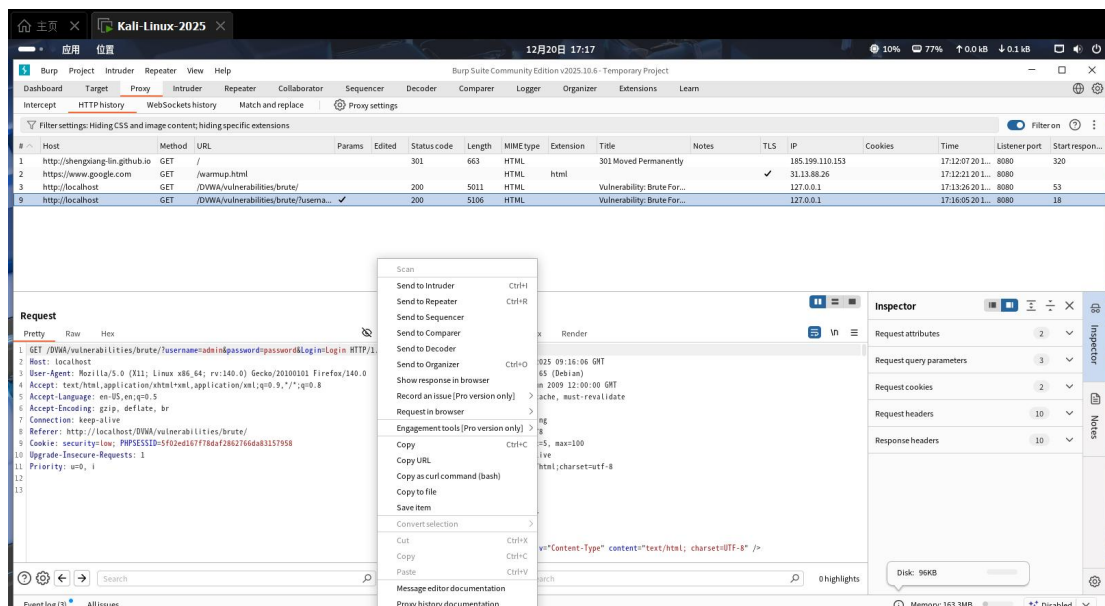
2.7.随便填写一个账号密码，然后提交登录。



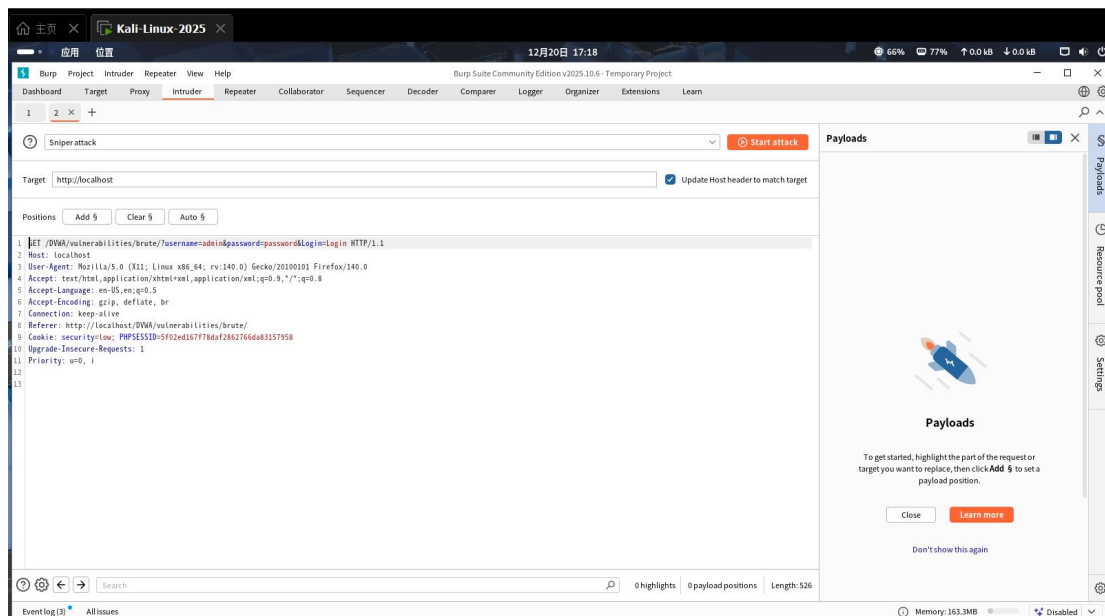
可观察到 BurpSuite 拦截到了包，查看发现账号和密码为明文传输



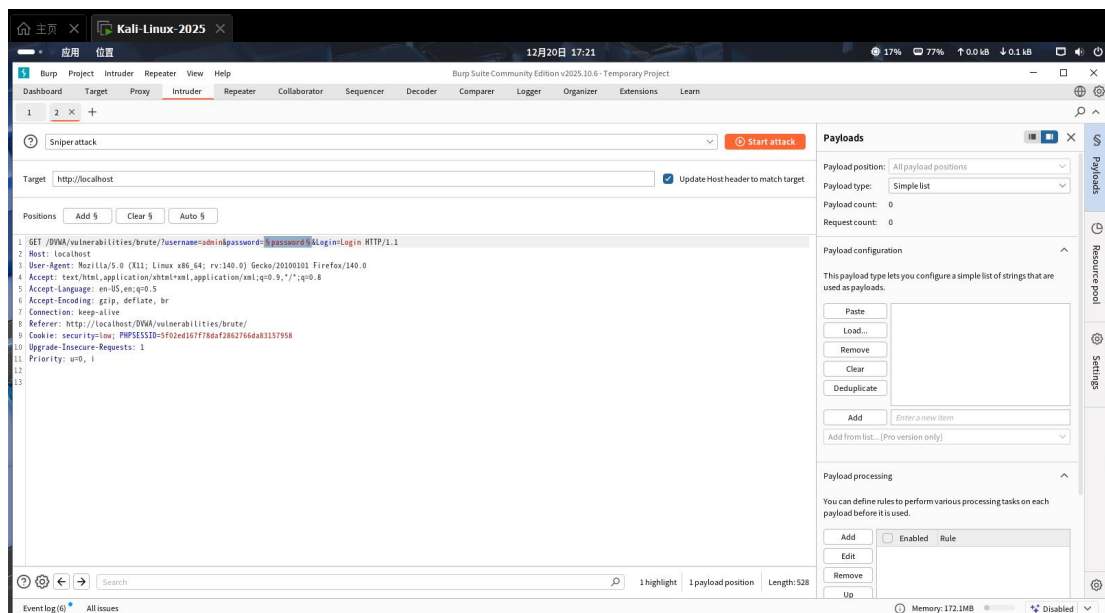
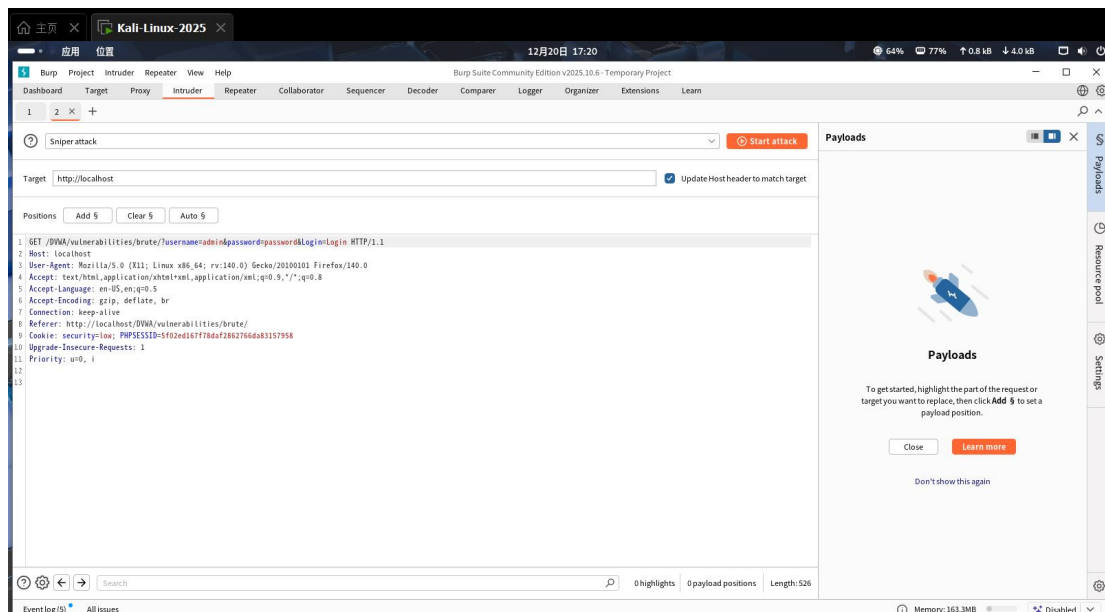
2.8.在 Request 区域右击鼠标，选择 Send to Intruder，准备爆破。



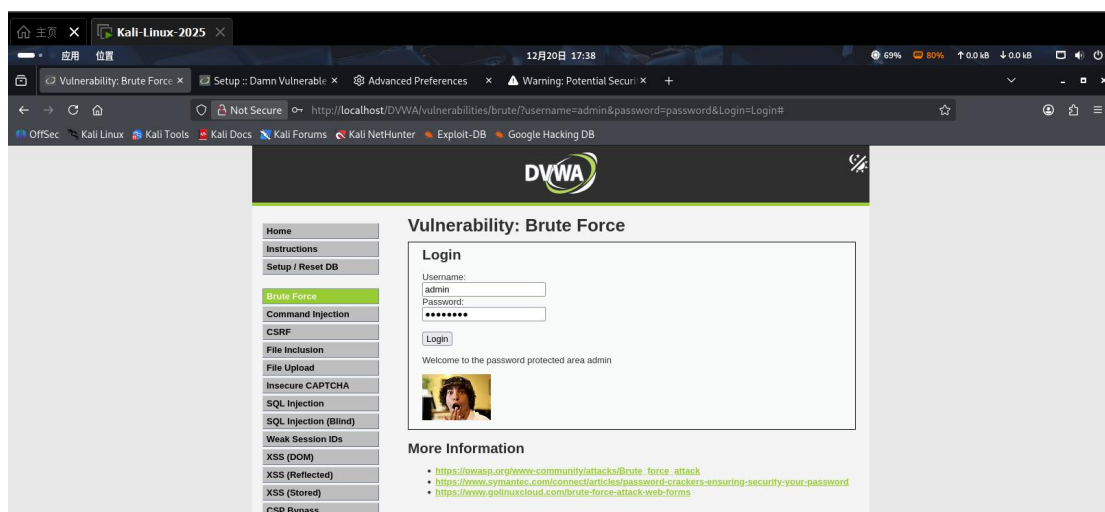
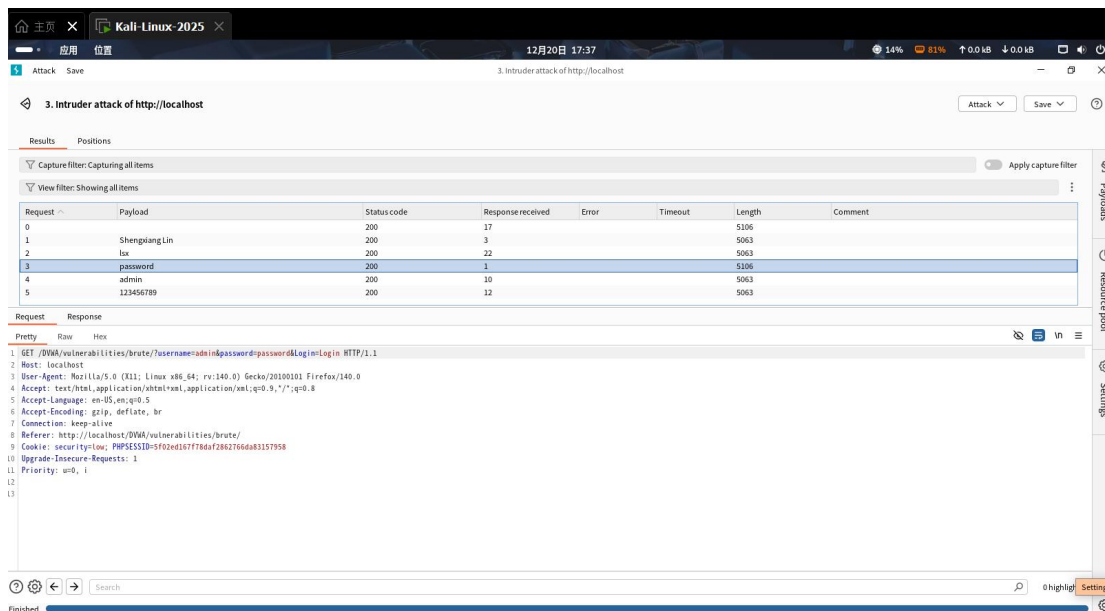
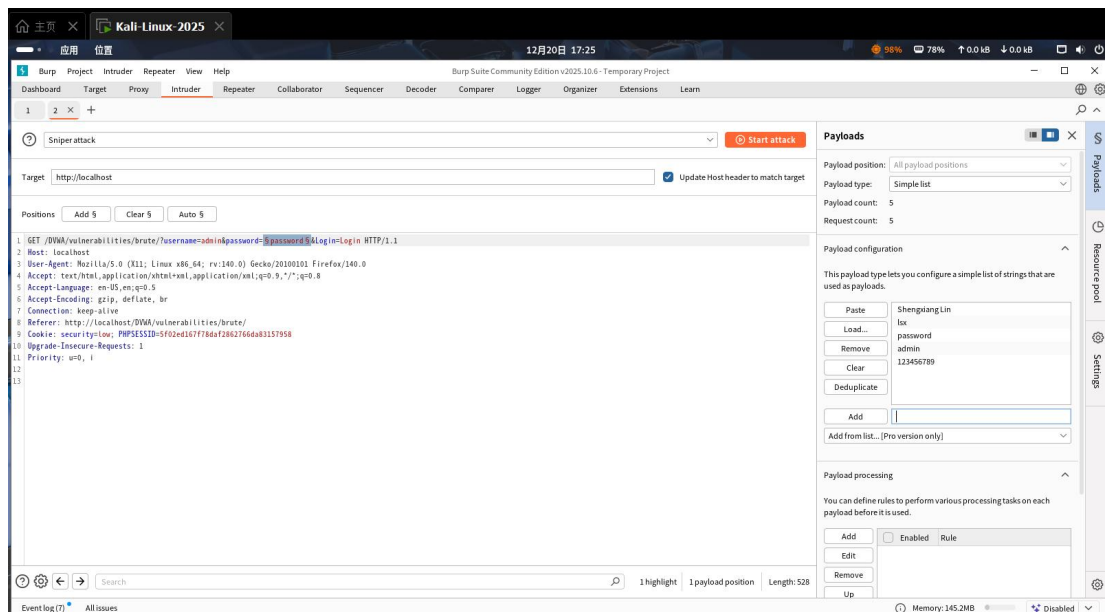
点击上方菜单栏的 Intruder，进入 Intruder 界面。



2.9.在 low 模式下我们只需要爆破密码，点击 clear 先清除自动标记的参数（如果有自动标记的话），然后手动选中密码，点击 add 标记参数，如右图所示。

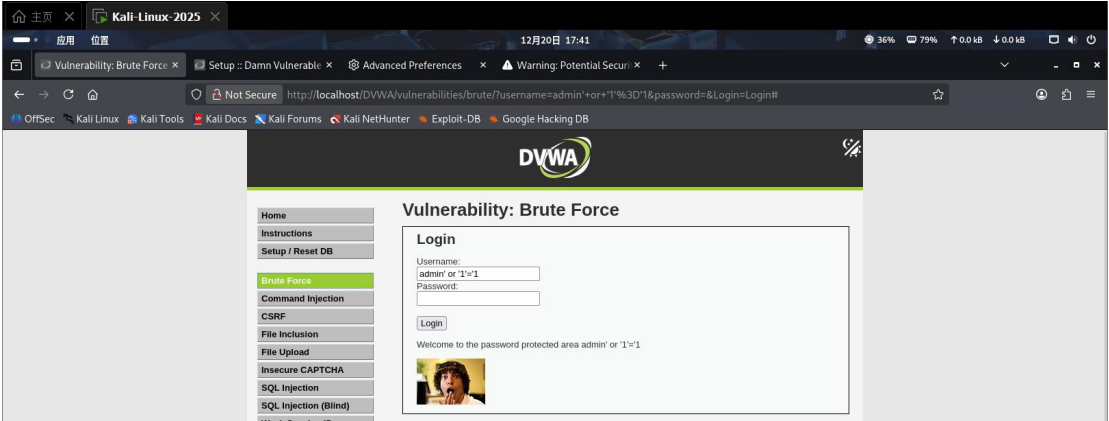


2.10. 点击 payload 标签，在 simple list 中添加字典，随便填加几个或者导入字典文件都行，添加完成后点击 start attack. 查看结果，发现有一个包返回的长度跟别的有明显差异，就是爆破正确的密码，然后返回页面，输入密码登录，可登陆成功。



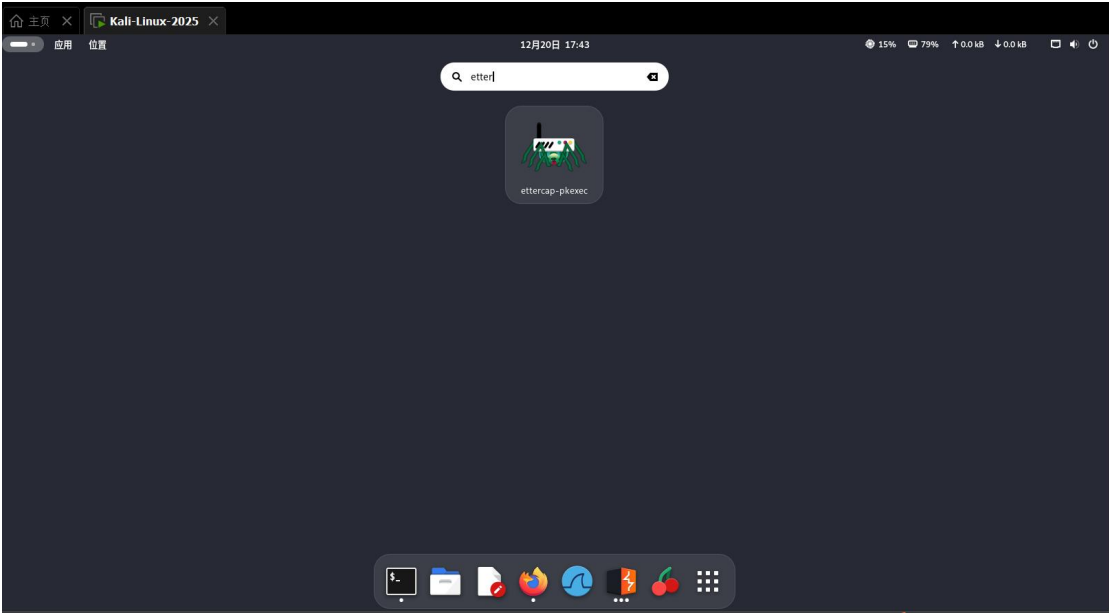
3.SQL 注入

在刚才的界面，在用户名一栏输入 `admin' or '1'='1` ,密码留空，发现还是可以成功登陆，说明该页面存在 SQL 注入漏洞，英文引号！！



4.基于 ARP 协议漏洞的中间人攻击

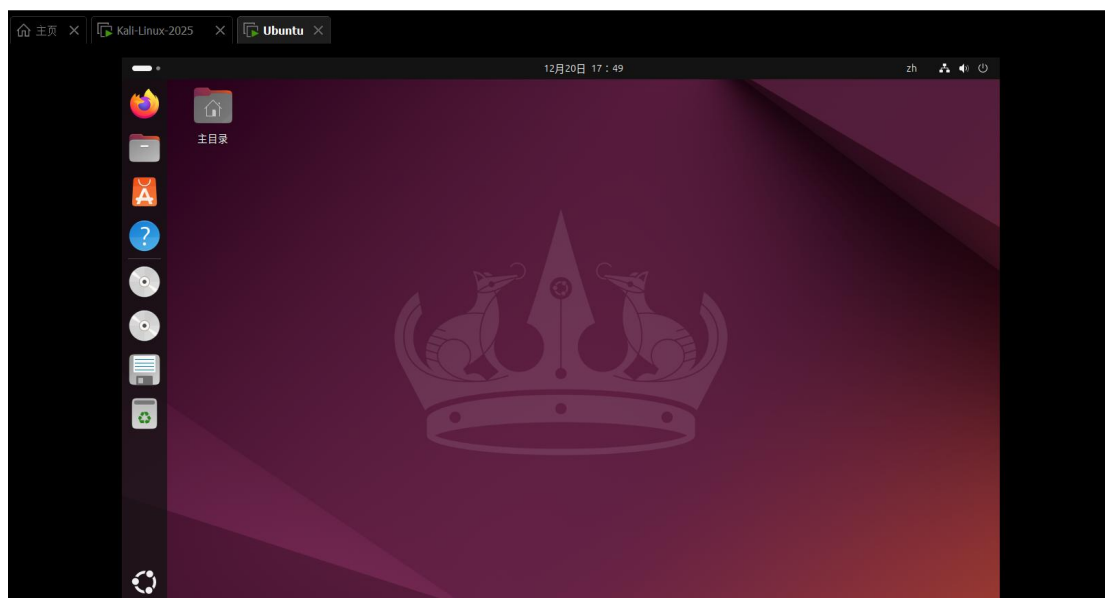
4.1.Kali 中自带 Ettercap。



打开软件，接受默认设置，进入界面后 Ettercap 会自动开始进行嗅探。



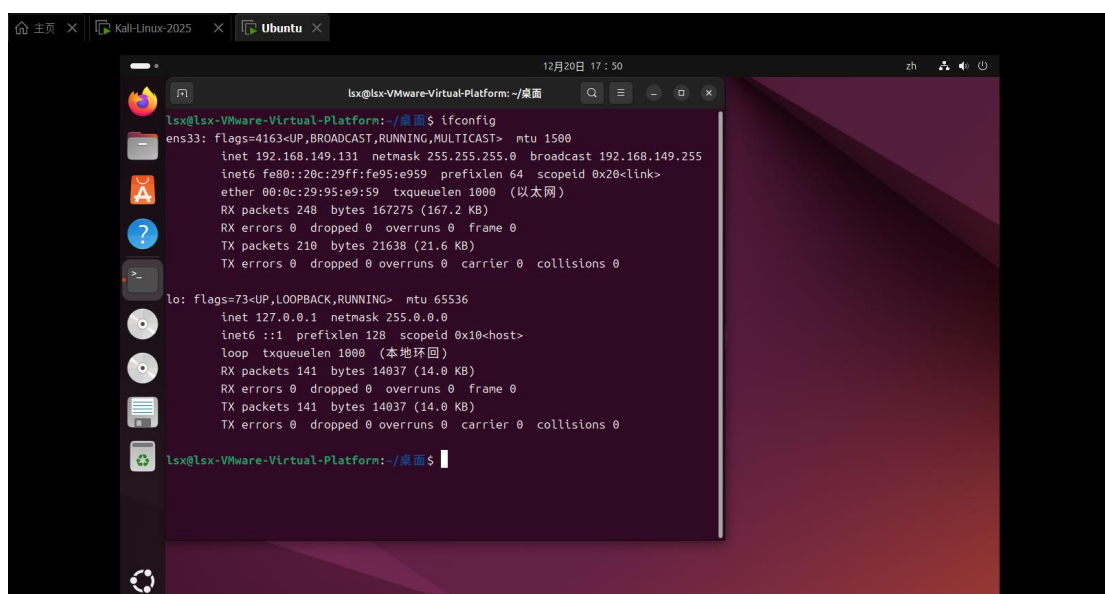
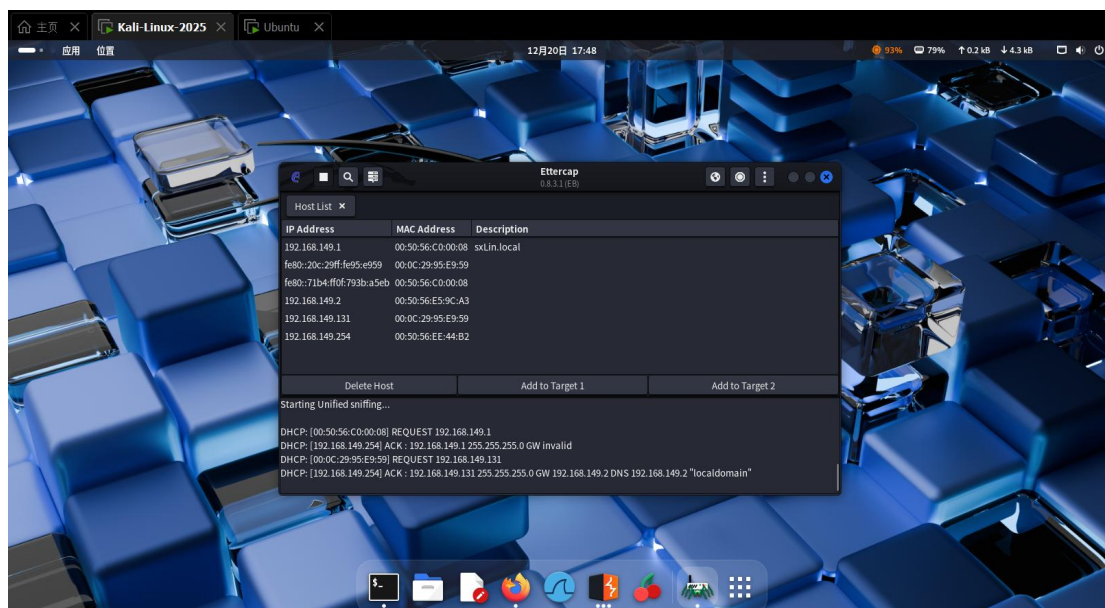
4.2.打开受害者主机（这里使用 Ubuntu，与 Kali 处于同一网段）。



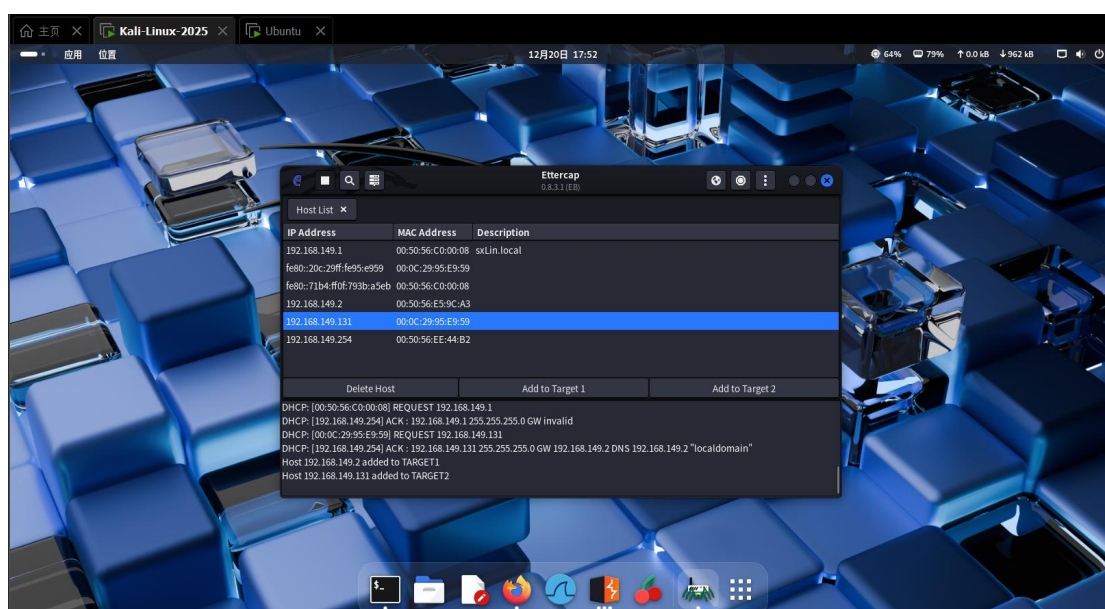
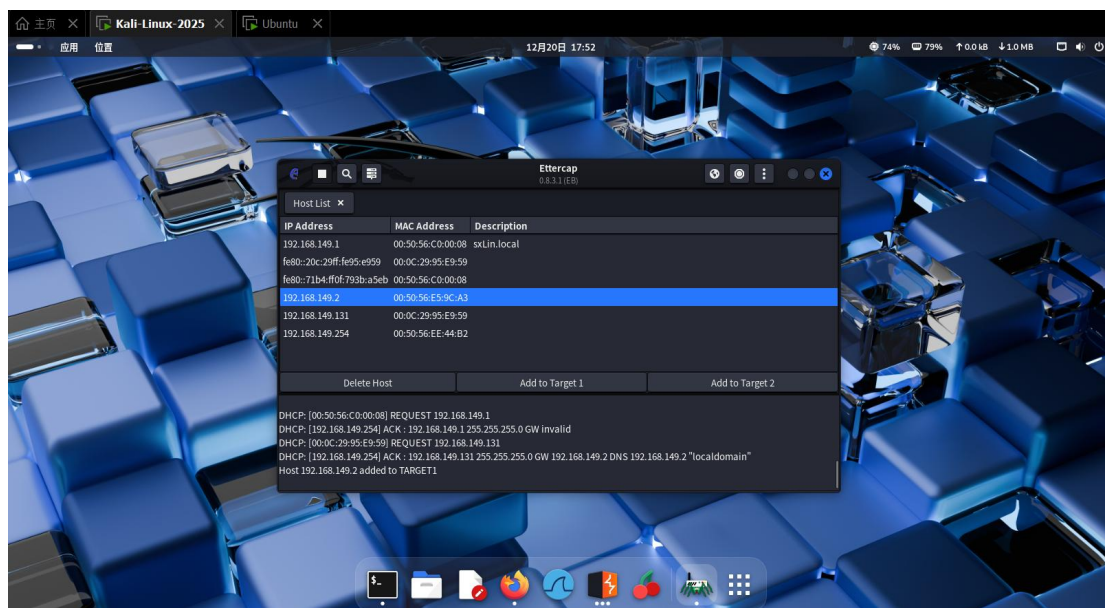
此时 Kali 上的 Ettercap 开始嗅探。



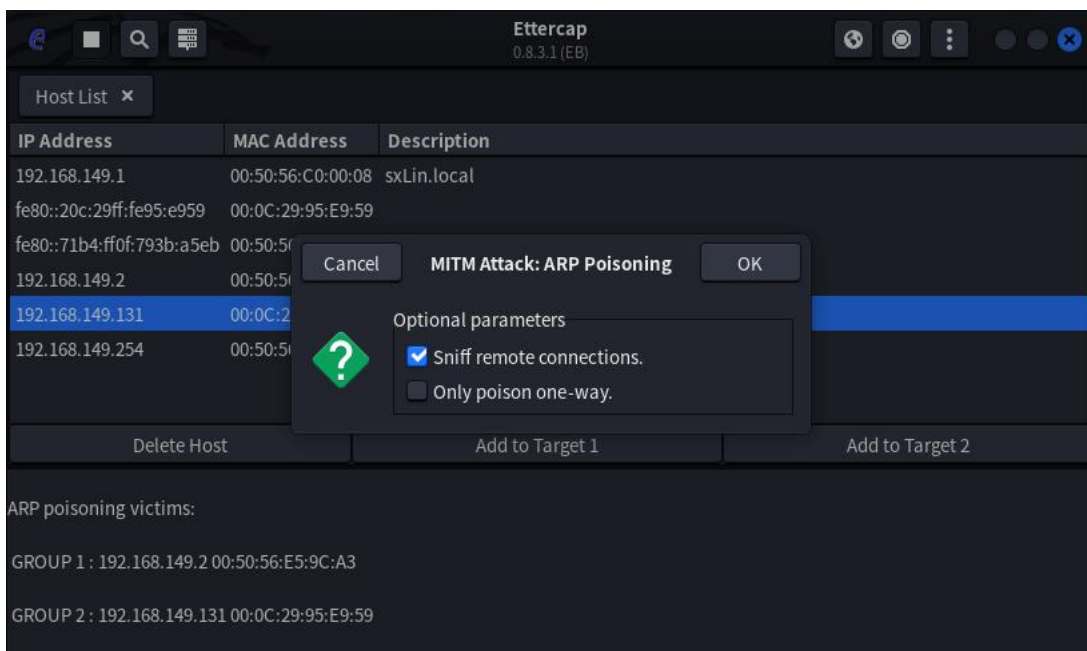
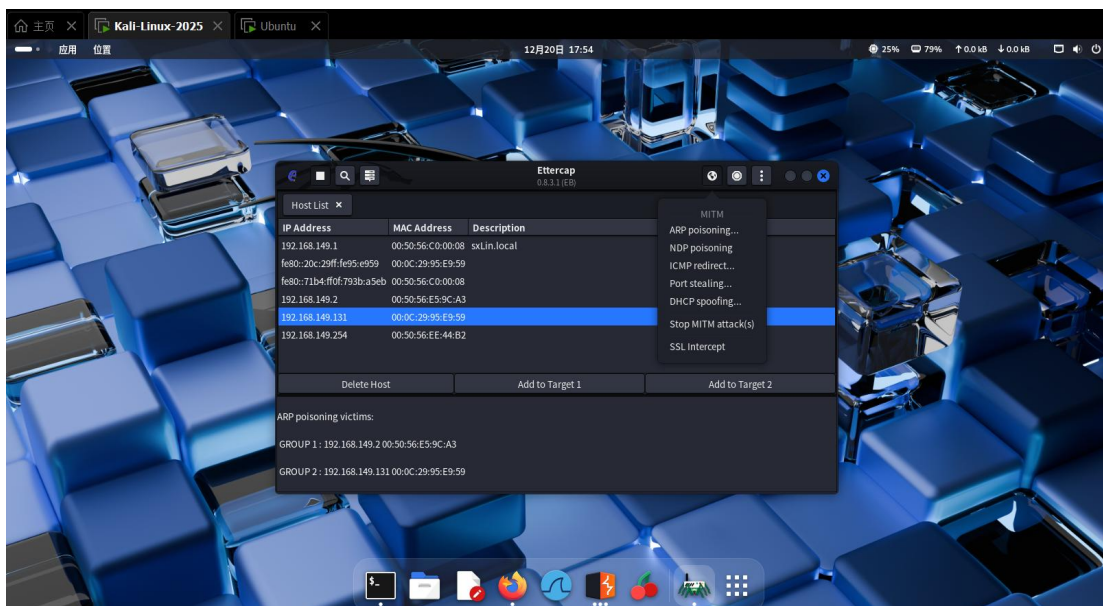
4.3.选择 Hosts->Scan for hosts 探，查看 Hosts->Hosts list，可看到多台机器，第一台有一台是网关（192.168.149.2），第二台是我们需要攻击的 Ubuntu（192.168.149.131）。



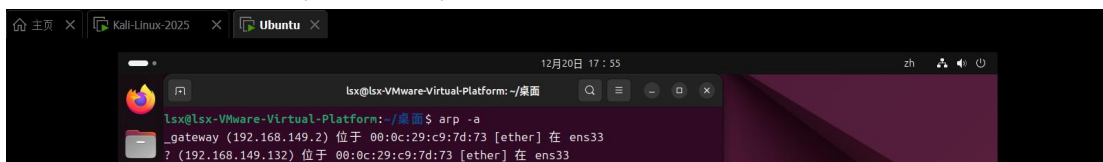
4.4.点击网关，选择 add to target1,再点击受害者的主机，选择 add to target2。



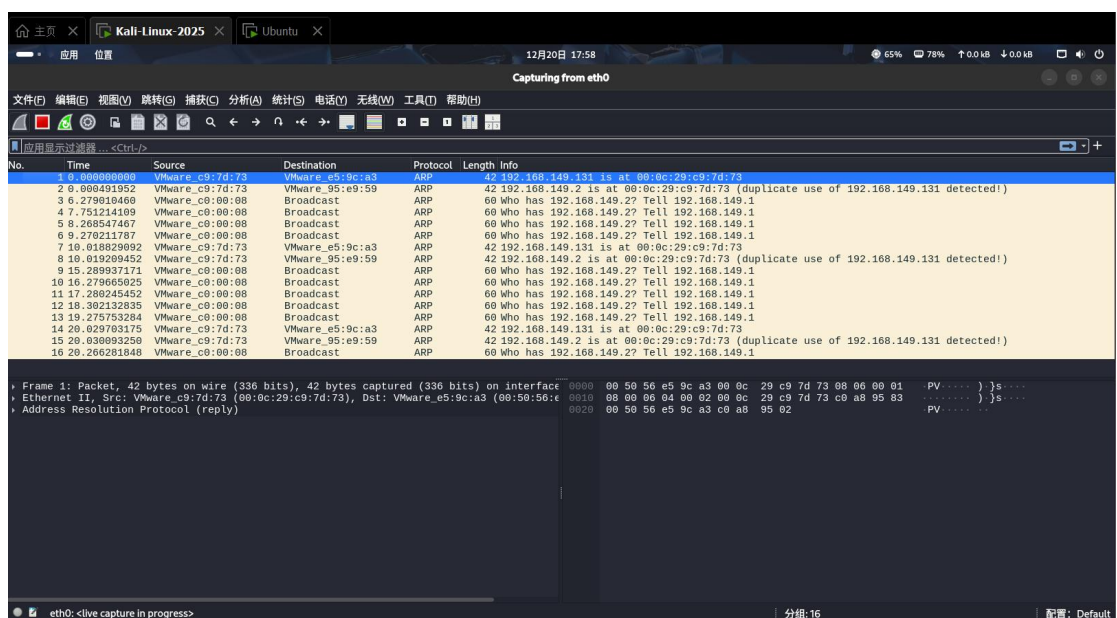
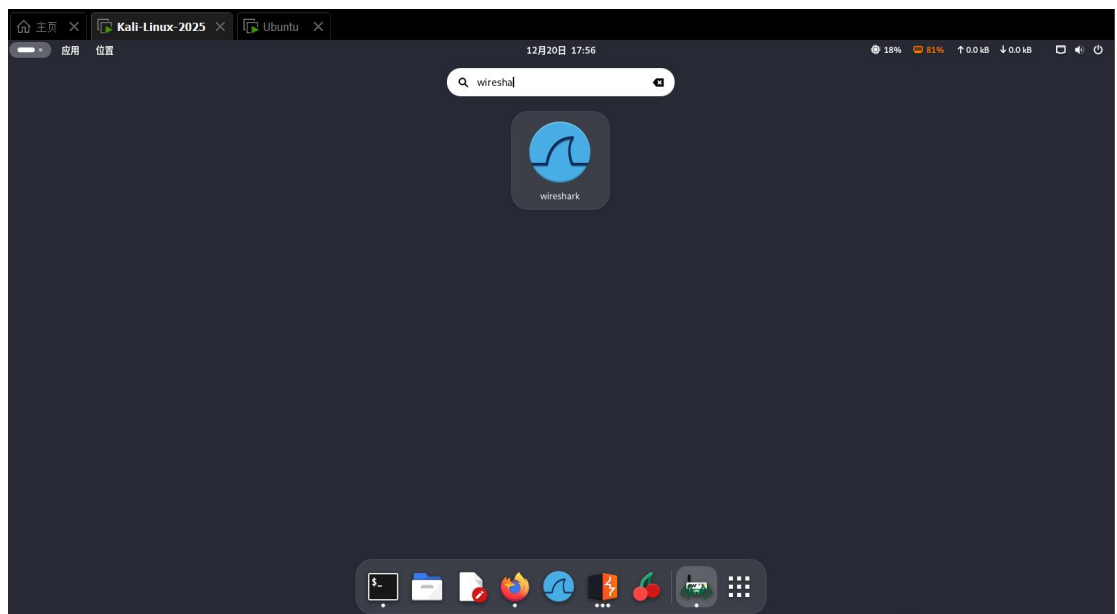
4.5.选择标签 Mitm 中 ARP poisoning，勾选第一个选项然后确定，这个时候就已经成功的发动了中间人攻击，受害者主机与网关之间的通信都会通过当前的攻击机。



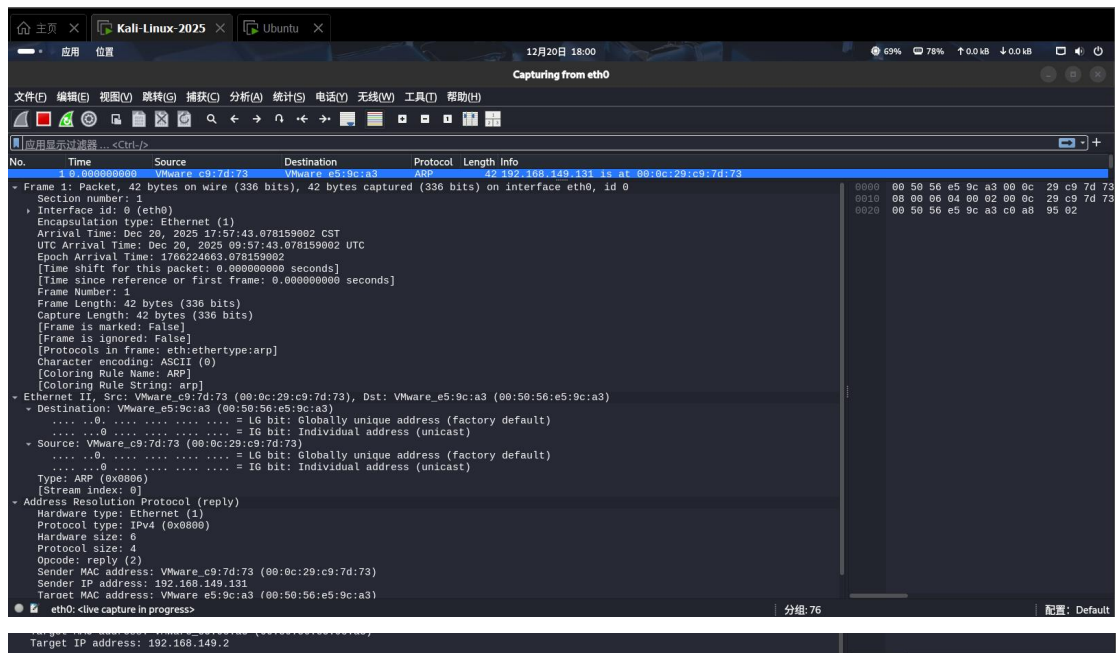
4.6.在受害主机上查看 arp 缓存表:arp -a 可以看到接口的地址是攻击者主机说明攻击成功。



4.7.在攻击者主机上打开 wireshark 进行抓包，准备查看 arp 协议数据包的内容并解释。



这里以 No.1 的 arp 协议响应数据包为例解释。



以太网帧部分（Ethernet II）：以太网是数据链路层的封装，负责将 ARP 数据包传到网络中。

目的 MAC 地址（VMWare_e5:9c:a3 (00:50:56:e5:9c:a3)）：这是数据包要发往的目标设备的 MAC。

源 MAC 地址（VMWare_c9:7d:73 (00:0c:29:c9:7d:73)）：这是发送这个 ARP 请求的设备的 MAC 地址。

类型字段（0x0806）：表示以太网帧承载的上层协议是 ARP（若为 0x0800 则是 IPv4）。

ARP 协议部分（地址解析协议）：这是数据包的核心，用于 IP 与 MAC 的映射查询。

硬件类型（Ethernet (1)）：表示使用的硬件是以太网（对应 MAC 地址）。

协议类型（IPv4 (0x0800)）：表示要解析的是 IPv4 地址（而非 IPv6）。

硬件大小（6）：以太网 MAC 地址的长度是 6 字节。

协议大小（4）：IPv4 地址的长度是 4 字节。

操作码（request (2)）：表示这是一个“ARP 相应”。

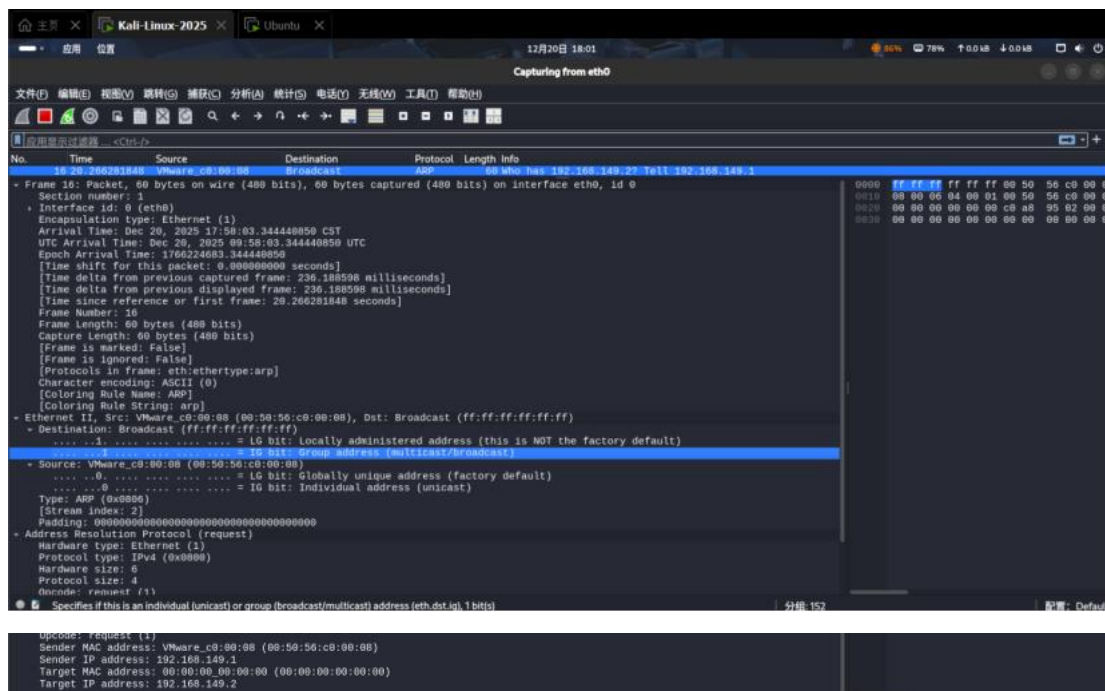
发送者 MAC 地址（VMWare_c9:7d:73 (00:0c:29:c9:7d:73)）：发送请求的设备的 MAC（和以太网帧的源 MAC 一致）。

发送者 IP 地址（192.168.131.133）：送请求的设备的 IP 地址。

目标 MAC 地址（VMWare_e5:9c:a3 (00:50:56:e5:9c:a3)）：这是待查询的 MAC 地址。

目标 IP 地址（192.168.131.2）：这是要查询 MAC 地址的目标设备的 IP 地址。

这里以 No.16 的 arp 协议请求数据包为例解释。



以太网帧部分（Ethernet II）：以太网是数据链路层的封装，负责将 ARP 数据包传到网络中。

目的 MAC 地址（Broadcast (ff:ff:ff:ff:ff:ff)）：这是数据包要发往的目标设备的 MAC，此处为广播地址，意味着发往同一网络内的所有设备。

源 MAC 地址（VMware_c8:00:08 (00:50:56:c0:00:08)）：这是发送这个 ARP 请求的设备的 MAC 地址。

类型字段（0x0806）：表示以太网帧承载的上层协议是 ARP。

ARP 协议部分（地址解析协议）：这是数据包的核心，用于 IP 与 MAC 的映射查询。

硬件类型（Ethernet (1)）：表示使用的硬件是以太网（对应 MAC 地址）。

协议类型（IPv4 (0x0800)）：表示要解析的是 IPv4 地址（而非 IPv6）。

硬件大小（6）：以太网 MAC 地址的长度是 6 字节。

协议大小（4）：IPv4 地址的长度是 4 字节。

操作码（request (1)）：表示这是一个“ARP 请求”（操作码 2 对应 ARP 响应）。

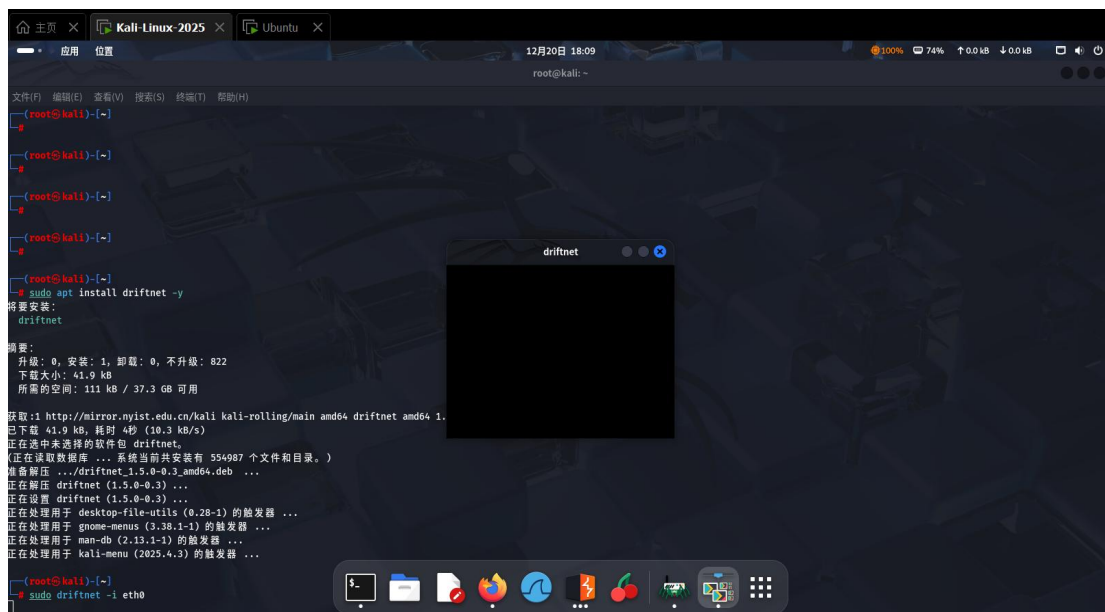
发送者 MAC 地址（VMware_c8:00:08 (00:50:56:c0:00:08)）：发送请求的设备的 MAC（和以太网帧的源 MAC 一致）。

发送者 IP 地址（192.168.149.1）：发送请求的设备的 IP 地址。

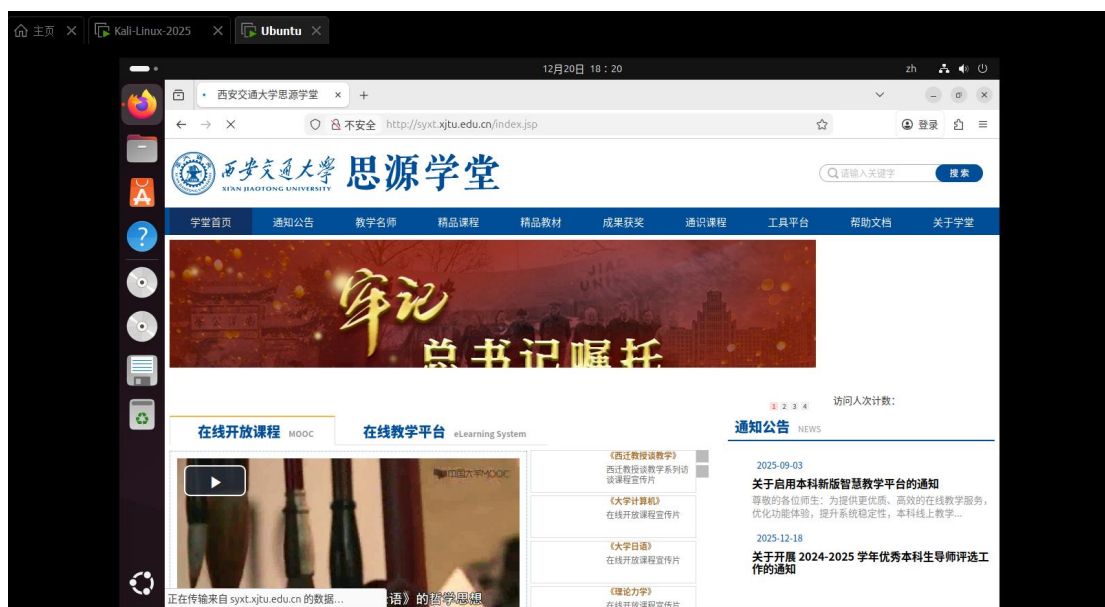
目标 MAC 地址（00:00:00_00:00:00 (00:00:00:00:00:00)）：这是待查询的 MAC 地址，此处为全 0 表示尚未知晓目标 MAC。

目标 IP 地址（192.168.149.2）：这是要查询 MAC 地址的目标设备的 IP 地址。

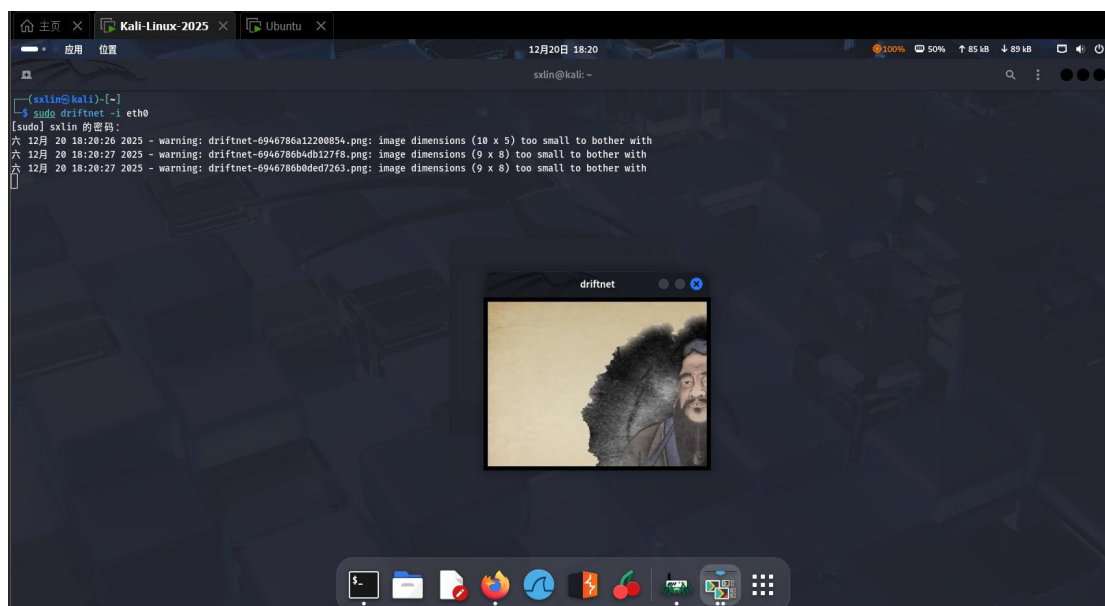
4.8.打开 driftnet, sudo driftnet -i 网卡名。



4.9.在受害者主机上随便打开一个未加密的 http 网页，比如我校的思源学堂。



4.10.观察 driftnet 的嗅探情况，可以发现 driftnet 已经有嗅探到了图片，说明中间人攻击生效。



五、思考题

查阅资料并思考如何针对实验涉及的漏洞进行防御。

暴力登录

- ①登录尝试限制：对同一 IP 或账户在特定时间窗口内的失败登录次数进行限制，超出阈值后自动锁定或延迟响应。
- ②验证码机制：在多次尝试失败后引入验证码（如 CAPTCHA），或直接全程要求验证，增加自动化攻击难度。
- ③强密码策略：强制用户设置包含大小写字母、数字及特殊符号的复杂密码，并设定最小长度与定期更新要求。
- ④多因素认证（MFA）：在密码验证基础上，结合手机短信验证码、认证应用动态口令（如 TOTP）或生物特征等方式进行二次验证。
- ⑤行为分析与设备指纹：记录登录来源、时间、设备等信息，通过异常检测模型识别可疑登录行为。

SQL 注入

- ①参数化查询（预处理语句）：使用 PDO、MySQLi 等数据库扩展的预处理功能，严格区分代码与数据，杜绝注入可能。
- ②输入验证与过滤：对用户输入进行白名单验证，仅允许符合预期格式的数据通过，并对特殊字符进行转义处理（如 `mysqli_real_escape_string()`）。
- ③安全密码存储：使用 `password_hash()` 与 `password_verify()` 进行密码哈希处理，避免使用 MD5、SHA-1 等弱哈希算法。
- ④最小权限原则：数据库连接账户应仅具备必要权限，避免使用高权限账号运行应用查询。
- ⑤Web 应用防火墙（WAF）：部署 WAF 规则库，实时检测并拦截常见的 SQL 注入攻击特征。

ARP 欺骗

- ①静态 ARP 绑定：在关键主机、网关等设备上设置静态 ARP 条目，将 IP 与 MAC 地址固定映射，防止缓存被篡改。适用于小型稳定网络。
- ②交换机安全功能：启用动态 ARP 检测（DAI）和 IP 源防护（IPSG），限制非法 ARP 报文的

传播，并验证 ARP 响应与端口绑定关系。

③网络加密与隧道化：通过 VPN（如 IPsec、WireGuard）或 TLS/HTTPS 对通信内容加密，即使流量被截获也难以解密。

④网络分段与隔离：划分 VLAN，限制广播域范围，减少 ARP 欺骗的影响面积。

⑤主动监测与告警：部署网络监控工具或入侵检测系统（IDS），识别异常的 ARP 请求/应答模式，并及时告警。

⑥终端防护：在主机上安装 ARP 防火墙软件，或通过系统设置拒绝非信任的 ARP 更新。

六、实验问题以及解决过程

1.在执行 `sudo bash -c "$(curl ...)"` 命令直接安装时，由于默认代理导致无法访问 GitHub 仓库，转而采用更稳妥的分步方案：首先使用 `wget` 将安装脚本下载到本地，然后赋予执行权限，最后以 `sudo` 权限运行。

2.在进行基于 ARP 欺骗的中间人攻击实验时，发现当受害者主机访问网页时，`driftnet` 并未如预期捕获并更新显示流量中的图像。经排查，原因是目标网页采用了 HTTPS 加密协议，导致传输内容无法被直接嗅探。后续将网页协议改为未加密的 HTTP 后，`driftnet` 便能够正常嗅探并提取出明文传输的图像数据。

七、实验小结

本次实验通过搭建 DVWA 靶场，综合实践了暴力破解、SQL 注入与 ARP 欺骗三种典型网络攻击。在暴力破解环节，利用 BurpSuite 对登录接口进行密码爆破，验证了弱密码风险；通过构造 SQL 注入 Payload 成功绕过身份验证，直观体会到输入过滤的重要性；在 ARP 中间人攻击中，借助 Ettercap 实施欺骗，并结合 `driftnet` 捕获明文传输的图片，进一步认识到未加密通信的脆弱性。实验过程中也遇到了代理设置、HTTPS 加密导致嗅探失效等问题，通过调整配置与目标网站得以解决。本次实验加深了我对常见漏洞原理与危害的理解，并促使我深入思考相应的安全防护措施。